

Table of Contents

1. Introduction
 - 1.1. Scope and Assumptions
2. How To Read This Document
3. Document Health Snapshot
4. Terms and Definitions
5. Architecture Decision Records
 - 5.1. Diagram Color and Shape Legend
6. Architecture Intent View
 - 6.1. What This View Answers
 - 6.2. System Boundary Diagram
 - 6.3. System Decomposition Diagram
 - 6.4. Functional Group Manhattan Matrix
 - 6.5. Functional Groups and Units (View Scoped)
7. Communication View
 - 7.1. What This View Answers
 - 7.2. Coverage Gaps
 - 7.3. Recommended Next Evidence Additions
 - 7.4. Communication Path Graph
 - 7.5. Functional Groups and Units (View Scoped)
8. Deployment View
 - 8.1. What This View Answers
 - 8.2. Coverage Gaps
 - 8.3. Recommended Next Evidence Additions
 - 8.4. Deployment Artifact Relationship Graph
 - 8.5. Platform Operations Graph
 - 8.6. Functional Groups and Units (View Scoped)
9. Security View
 - 9.1. What This View Answers
 - 9.2. Coverage Gaps
 - 9.3. Recommended Next Evidence Additions
 - 9.4. Threat Model Context Diagram
 - 9.5. Threat Scenario Register
 - 9.6. Threat Mitigation Coverage
 - 9.7. Security Flow Semantics
 - 9.8. Threat Assumptions
 - 9.9. Threat Model Out-of-Scope Decisions
 - 9.10. Security Logging and Observability
 - 9.11. Attack Vector Chapters
10. Traceability View
 - 10.1. What This View Answers
 - 10.2. Coverage Gaps
 - 10.3. Recommended Next Evidence Additions
11. State Lifecycle View

11.1. What This View Answers
11.2. State Lifecycle Diagram
11.3. Coverage Gaps
11.4. Recommended Next Evidence Additions
11.5. Functional Groups and Units (View Scoped)
12. Interaction Flow View
12.1. What This View Answers
12.2. Interaction Flow Diagram
12.3. Coverage Gaps
12.4. Recommended Next Evidence Additions
12.5. Functional Groups and Units (View Scoped)
12.6. Requirement-to-Unit Mapping (Compact)
12.7. Verification Result Mapping
13. Traceability Appendix
13.1. Requirement Details
13.2. Verification Inventory
14. Reference Index
14.1. Authored References
14.2. Catalog References
14.3. Inferred Runtime References
14.4. Inferred Code References
14.5. Verification References
15. Gemara GRC Model
15.1. Controls (L2)
15.2. Threats (L2)
15.3. Risks (L3)

1. Introduction

This document describes the `payments` architecture using authored functional design and inferred runtime/code realization. It is intended to help product, platform, security, and implementation engineers reason about one shared `model`. Functional design is kept stable while realization details are inferred from infrastructure and source artifacts.

1.1. Scope and Assumptions

- `Functional Groups` and `Functional Units` are the stable authored design backbone.
- `Runtime elements` and `code elements` are inferred from available IaC, deployment, and source artifacts.
- Inferred coverage is evidence-driven and may be partial when source metadata is missing.
- `Requirements` and reference indexes are provided for traceability, not as primary narrative flow.

2. How To Read This Document

This document is intentionally split into two layers:

1. Concept layer: functional and view-specific architecture narratives for human understanding.

2. Evidence layer: generated requirement traceability and inferred reference indexes.

Read in this order:

1. Architecture Intent View: stable authored architecture intent and ownership boundaries.

2. Communication / Deployment / Security Views: viewpoint-specific operational behavior.

3. Traceability View: requirement mapping, evidence coverage, and confidence.

4. Reference Appendix: supporting reference IDs and inferred-source links.

3. Document Health Snapshot

View	Authored Status	Authored Status Explanation	Units in Scope	Direct Evidence Coverage	Gap Count	Heuristic Confidence	Heuristic Basis
Architecture Intent View (VIEW-ARCHITECTURE-INTENT)	stable	Stable authored capability boundaries and ownership split; changes are intentional and infrequent.	6	6	0	high	Defaults authored units to covered; use authoredStatus as the primary publication signal.
Communication View (VIEW-COMMUNICATION)	in-review	Communication semantics are partially inferred and still being refined with explicit protocol and interaction metadata.	4	3	1	medium	Counts a unit as covered when direct inferred runtime evidence exists.
Deployment View (VIEW-DEPLOYMENT)	in-review	Deployment chain and control-plane mapping are mostly present, but ownership evidence remains incomplete for some units.	6	5	1	high	Counts a unit as covered when direct inferred runtime evidence exists.
Security View (VIEW-SECURITY)	draft	Threat mapping is present for key vectors, but control expectations and coverage breadth are still evolving.	4	4	0	high	Counts a unit as covered when explicit authored attack-vector mapping exists.

View	Authored Status	Authored Status Explanation	Units in Scope	Direct Evidence Coverage	Gap Count	Heuristic Confidence	Heuristic Basis
Traceability View (VIEW-TRACEABILITY)	in-review	Requirement-to-unit linkage is present; cross-layer ownership consistency still needs tightening.	6	5	4	high	Counts a unit as covered when direct inferred runtime or code evidence exists.
State Lifecycle View (VIEW-STATE-LIFECYCLE)	in-review	Lifecycle transitions and controls are explicitly modeled for payment decision progression.	0	0	0	n/a	Lifecycle heuristic is currently basic; treat authoredStatus as primary signal.
Interaction Flow View (VIEW-INTERACTION-FLOW)	in-review	Flow is authored for core checkout path and used to align UX/data movement semantics with architecture behavior.	4	4	0	high	Flow heuristic is step/branch-oriented; treat authoredStatus plus projection completeness as the primary signal.

4. Terms and Definitions

Term	Definition
3DS verification is required (COND-3DS-REQUIRED)	Condition indicating strong customer authentication must be performed. Aliases:3DS required
actor (TERM-ACTOR)	A person or operational role that interacts with functional units.
architecture decision (TERM-DECISION)	Authored architecture decision record with status, context, decision text, and consequences.
AsciiDoc diagram (TERM-ASCIIDOC-DIAGRAM)	Generated diagram block, usually Mermaid, that visualizes architecture relationships in the AsciiDoc publication.
AsciiDoc document (TERM-ASCIIDOC-DOCUMENT)	Human-readable generated architecture publication document assembled from authored model, inferred evidence, diagrams, references, and decisions.

Term	Definition
AsciiDoc section (TERM-ASCIIDOC-SECTION)	Structured generated document section or row model used to render authored and inferred architecture content.
attack vector (TERM-ATTACK-VECTOR)	A technical misuse or attack path that targets functional, referenced, or runtime elements.
authored mapping (TERM-AUTHORED-MAPPING)	An explicit relationship declared in architecture inputs between authored or referenced elements.
bank gateway endpoint (REF-BANK-GATEWAY-ENDPOINT)	External banking endpoint used for card authorization and decline decisions. Aliases:bank API
bank link is available (STATE-BANK-LINK-UP)	Connectivity state showing bank gateway communication is currently healthy. Aliases:bank link up
bank link is unavailable (EVT-BANK-LINK-UNAVAILABLE)	Event raised when payment engine cannot reach the external bank gateway. Aliases:bank link down
catalog (TERM-CATALOG)	Controlled vocabulary document used to normalize model, requirement, and generated-document terminology.
catalog entry (TERM-CATALOG-ENTRY)	A stable catalog term with a definition and aliases for linting, linking, and generated references.
checkout handling (FU-CHECKOUT)	Handles checkout session start and customer-facing payment messaging. Aliases:checkout
checkout is active (STATE-CHECKOUT-ACTIVE)	Processing state where the user is actively submitting or confirming payment. Aliases:checkout active
CLI command (TERM-CLI-COMMAND)	Command-line entrypoint that coordinates loading, validation, generation, and file output for an engineering-model workflow.
cluster provisioning (FU-CLUSTER-PROVISIONING)	Provides cluster-level platform setup and environment bootstrap. Aliases:day1 provisioning
code element (TERM-CODE-ELEMENT)	An inferred code structure or ownership element discovered from source trees and build metadata.
compliance mapping (TERM-COMPLIANCE-MAPPING)	Authored mapping that links a model control to selected compliance controls, model scope, implementation status, evidence, and responsible roles.
compromised dependency (AV-COMPROMISED-DEPENDENCY)	Supply-chain compromise in runtime image or code dependency. Aliases:dependency compromise
control (TERM-CONTROL)	An authored security, policy, or operational control used to constrain behavior and reduce risk.

Term	Definition
control verification (TERM-CONTROL-VERIFICATION)	Authored control verification record with method, status, threat/risk scope, findings, and evidence.
customer (ACT-CUSTOMER)	End user submitting payment details during checkout. Aliases:buyer
data object (TERM-DATA-OBJECT)	An authored data artifact or contract shape traced across flow, interface, and implementation boundaries.
decline reason (DATA-DECLINE-REASON)	Structured reason code or message explaining why authorization failed. Aliases:decline code, decline reasons
deployment target (TERM-DEPLOYMENT-TARGET)	An authored deployment destination such as environment, cluster, namespace, or registry scope.
design document (TERM-DESIGN)	Authored design narrative organized by model entities and architecture views.
design view (TERM-DESIGN-VIEW)	View-scoped design narrative attached to an authored functional group or functional unit.
event (TERM-EVENT)	An authored trigger signal that drives transitions, flow progress, or asynchronous outcomes.
evidence (TERM-EVIDENCE)	A file, artifact, or observation used to support control, risk, threat, or verification claims.
flow (TERM-FLOW)	An authored causal interaction sequence from user/system intent to outcome, represented as ordered steps.
flow step (TERM-FLOW-STEP)	A single authored step in a flow that captures action, data in/out, references, and normal/error/async transitions.
fraud check is enabled (FEAT-FRAUD-CHECK)	Feature flag controlling whether risk scoring is required before authorization. Aliases:fraud check
fraud detection system (SYS-FRAUD-DETECTION-SYSTEM)	Fraud scoring and review subsystem participating in payment decisions. Aliases:the fraud detection system
fraud evaluation (FG-FRAUD)	Functional group for risk scoring and fraud review capabilities. Aliases:fraud domain
fraudulent transaction pattern (AV-FRAUDULENT-TRANSACTION-PATTERN)	Coordinated abuse pattern using synthetic identities, stolen instruments, or velocity anomalies to obtain unauthorized approvals. Aliases:fraud abuse, payment fraud
functional group (TERM-FUNCTIONAL-GROUP)	A major authored capability area that groups related functional units.
functional unit (TERM-FUNCTIONAL-UNIT)	An authored working unit inside a functional group that owns specific behavior.

Term	Definition
generation workflow (TERM-GENERATION-WORKFLOW)	Orchestrated run that combines model loading, validation, projection, rendering, and artifact emission.
gitops operations (FU-GITOPS-OPERATIONS)	Operates declarative delivery and release management flows. Aliases:day2 operations
helm platform (REF-HELM-PLATFORM)	Runtime packaging and deployment substrate for workloads. Aliases:helm
inference hint (TERM-INFERENCE-HINT)	Authored source and ownership configuration used to discover runtime, code, and verification evidence.
inferred mapping (TERM-INFERRED-MAPPING)	A discovered relationship that links inferred runtime/code elements upward to authored design.
interface (TERM-INTERFACE)	An authored interface boundary (for example API, channel, endpoint, or contract) owned by a functional unit.
lint run (TERM-LINT-RUN)	Requirement lint configuration that controls parsing and quality checks for requirement text.
LOBSTER activity trace (TERM-LOBSTER-ACTIVITY-TRACE)	Generated LOBSTER activity JSON that links verification evidence back to formal requirement identifiers.
malicious api request (AV-MALICIOUS-API-REQUEST)	Crafted payload attempting to bypass validation or authorization logic. Aliases:malicious request
MCP server (TERM-MCP-SERVER)	Model Context Protocol server that exposes engineering-model operations to AI agents through JSON-RPC tools.
MCP stdio transport (TERM-MCP-STDIO-TRANSPORT)	Content-Length framed standard input/output transport used by the MCP command-line server.
MCP tool (TERM-MCP-TOOL)	Named MCP operation with a constrained input schema and structured response payload.
MCP tool response (TERM-MCP-TOOL-RESPONSE)	Structured MCP tool payload that includes success state, schema version, generated timestamp, and result data or validation error.
model (TERM-MODEL)	The authored architecture model root that composes functional structure, relationships, inference hints, and views.
model bundle (TERM-BUNDLE)	Loaded architecture, catalog, and companion documents resolved as one working model context.
normal mode is active (MODE-NORMAL)	Standard operating mode with full external dependency usage enabled. Aliases:normal mode, standard operating mode

Term	Definition
Open OTM document (TERM-OPEN-OTM-DOCUMENT)	Open Threat Model JSON representation generated from the engineering model for interoperable threat-model exchange.
OSCAL assessment results (TERM-OSCAL-ASSESSMENT-RESULTS)	Generated OSCAL assessment results that summarize reviewed controls, verification findings, and modeled risks.
OSCAL POA&M (TERM-OSCAL-POAM)	Generated OSCAL plan of action and milestones that maps modeled POA&M items and related risks into compliance JSON.
OSCAL SSP (TERM-OSCAL-SSP)	Generated OSCAL system security plan that maps authored system metadata, components, controls, allocations, and evidence into SSP JSON.
payment authorization (FU-PAYMENT-AUTHORIZATION)	Coordinates authorization flow and bank gateway interaction. Aliases:auth
payment authorization is requested (EVT-PAYMENT-AUTH-REQUESTED)	Event raised when checkout asks payment engine to authorize a transaction. Aliases:authorization requested, payment auth requested
payment id (DATA-PAYMENT-ID)	Stable identifier used to correlate a payment across services and records.
payment is declined (EVT-PAYMENT-DECLINED)	Event indicating authorization was rejected and customer decline handling must execute. Aliases:decline, payment declined
payment review is pending (STATE-REVIEW-PENDING)	Transaction state requiring manual support review before final disposition. Aliases:review pending, review state
payments (FG-PAYMENTS)	Functional group for checkout and authorization capabilities. Aliases:payments domain
payments system (SYS-PAYMENTS-SYSTEM)	Payment processing system-of-interest covered by this architecture. Aliases:the payments system
platform (FG-PLATFORM)	Functional group for provisioning and platform operations capabilities. Aliases:platform engineering
platform operator (ACT-PLATFORM-OPERATOR)	Role responsible for GitOps and platform lifecycle operations. Aliases:platform ops
POA&M item (TERM-POAM-ITEM)	Plan of action and milestones item linked to a modeled risk and supporting artifacts.
postgresql client driver (REF-POSTGRES-DRIVER)	Third-party library used for application data persistence connectivity. Aliases:postgres driver
reference index (TERM-REFERENCE-INDEX)	Generated index of authored, catalog, runtime, code, and verification references with stable anchors and backlinks.

Term	Definition
referenced element (TERM-REFERENCED-ELEMENT)	An architecture-relevant external, platform, or third-party dependency represented by role.
replayed authorization callback (AV-REPLAYED-AUTH-CALLBACK)	Replay of a valid callback to induce duplicate or unauthorized state transitions. Aliases:callback replay
repository index (TERM-REPO-INDEX)	Bounded first-party source index used to answer model-aware file, requirement, control, and threat lookup queries.
requirement (TERM-REQUIREMENT)	A structured requirement statement that defines expected system behavior and maps to functional ownership.
risk (TERM-RISK)	Authored risk record with likelihood, impact, response, scope, controls, and evidence.
risk score (DATA-RISK-SCORE)	Numeric fraud score produced by risk evaluation logic.
risk score is high (EVT-RISK-HIGH)	Event emitted when computed fraud risk exceeds the configured high-risk threshold. Aliases:high risk, high-risk classification, high-risk classifications
risk scoring (FU-RISK-SCORING)	Evaluates transaction risk and returns score classification. Aliases:fraud scoring
risk threshold is exceeded (COND-RISK-THRESHOLD-EXCEEDED)	Condition indicating risk score crossed a policy threshold for escalation. Aliases:risk above threshold
runtime element (TERM-RUNTIME-ELEMENT)	An inferred runtime realization element discovered from infrastructure and deployment sources.
security context (TERM-SECURITY-CONTEXT)	Security-focused generated context view that groups owned functional units and shows external actors, references, flows, controls, and trust boundaries.
source block (TERM-SOURCE-BLOCK)	Stable source reference block that records file path, optional line span, kind, summary, and linked entity IDs.
state (TERM-STATE)	An authored lifecycle state used to model transition behavior, guards, and event-driven progression.
Structurizr DSL (TERM-STRUCTURIZR-DSL)	Generated Structurizr DSL workspace that projects authored architecture, relationships, dynamic views, and deployment metadata.
support agent (ACT-SUPPORT)	Operations role that investigates declines and high-risk review cases. Aliases:support
support agent is notified (EVT-SUPPORT-NOTIFIED)	Event indicating manual review notification was sent to support operations. Aliases:support notified
support review (FU-SUPPORT-REVIEW)	Supports manual review and escalation handling for risky transactions. Aliases>manual review

Term	Definition
threat assumption (TERM-THREAT-ASSUMPTION)	Authored security assumption that records scope, rationale, owner, status, and evidence.
Threat Dragon document (TERM-THREAT-DRAGON-DOCUMENT)	Threat Dragon JSON representation generated from the engineering model for STRIDE threat-model review.
threat mitigation (TERM-THREAT-MITIGATION)	Authored mitigation record that links a threat scenario to a control, effectiveness, verification, and evidence.
threat model export (TERM-THREAT-MODEL-EXPORT)	Generated security artifact that translates authored architecture, flows, trust boundaries, threats, and mitigations into an external threat-model schema.
threat out-of-scope decision (TERM-THREAT-OUT-OF-SCOPE)	Authored decision that excludes a threat concern from current scope with reason, owner, expiry, and evidence.
threat scenario (TERM-THREAT-SCENARIO)	Authored threat narrative that connects attack vectors, scope, flows, controls, risks, and verification evidence.
trace marker (TERM-TRACE-MARKER)	Source-level marker such as TRLC-LINKS or ENGMODEL-LINKS used to connect declarations to requirements and model entities.
TRLC package (TERM-TRLC-PACKAGE)	Generated TRLC model and requirements package used for formal requirement traceability processing.
trust boundary (TERM-TRUST-BOUNDARY)	An authored trust separation zone that marks policy, identity, or security control boundaries.
upward linking (TERM-UPWARD-LINKING)	Rule where runtime and code elements point to stable functional groups/units; authored architecture does not depend on inferred IDs.
validation (TERM-VALIDATION)	Model quality gate that checks authored documents, references, relationship semantics, and requirement lint results.
validation diagnostic (TERM-VALIDATION-DIAGNOSTIC)	Structured validation finding with code, severity, message, and optional source path.
verification check (TERM-VERIFICATION-CHECK)	An inferred or authored verification artifact that validates requirement behavior with test evidence.
view (TERM-VIEW)	Authored projection configuration that selects roots, entity kinds, mappings, audience, and abstraction.

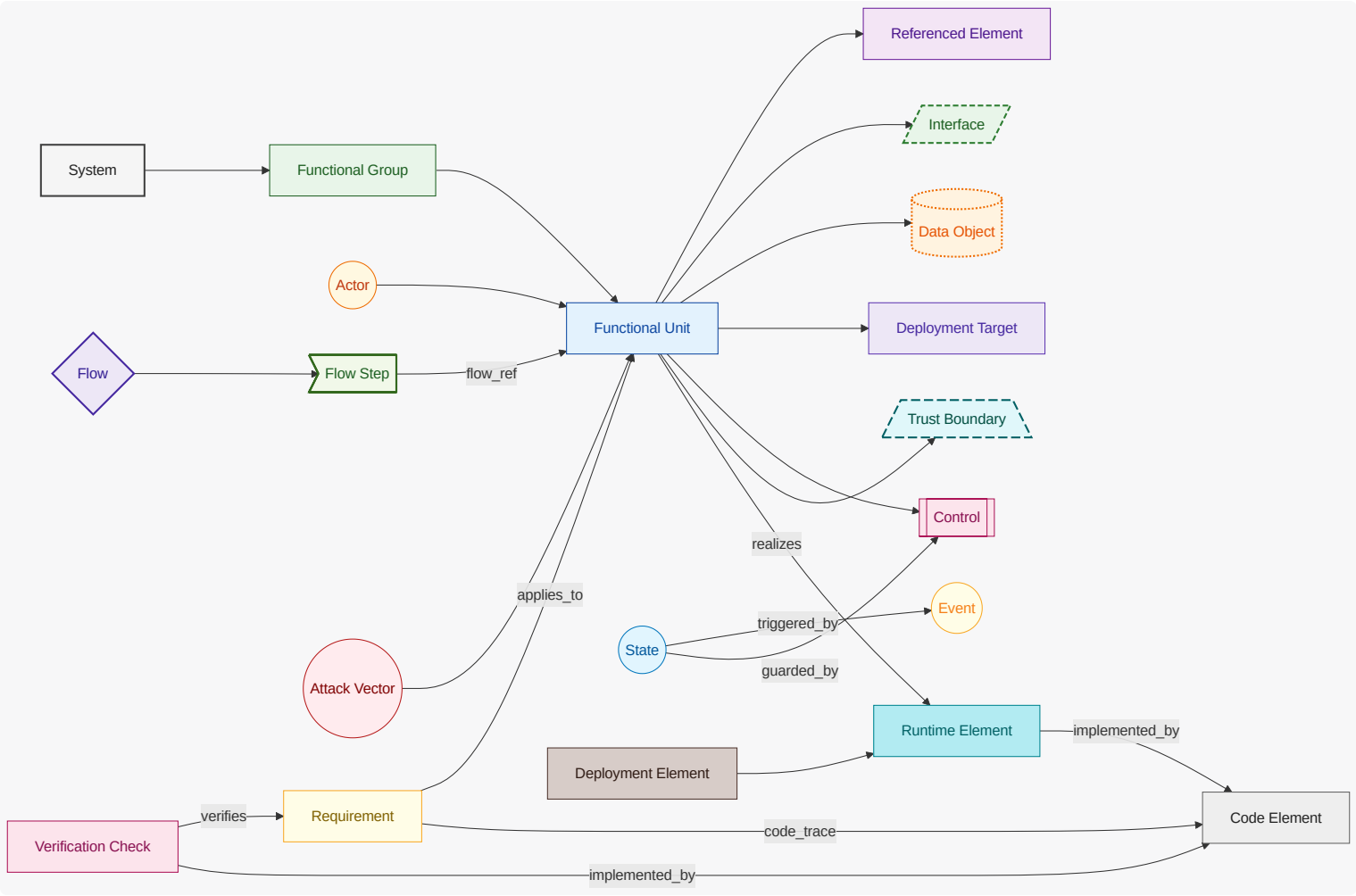
5. Architecture Decision Records

Architecture decision records are generated separately and linked here as a compact index.

ID	Title	Status	Date
<u>ADR-PAY-001</u>	Keep payment authorization separate from checkout handling	accepted	2026-04-29

5.1. Diagram Color and Shape Legend

This legend applies to all Mermaid diagrams in this document.



6. Architecture Intent View

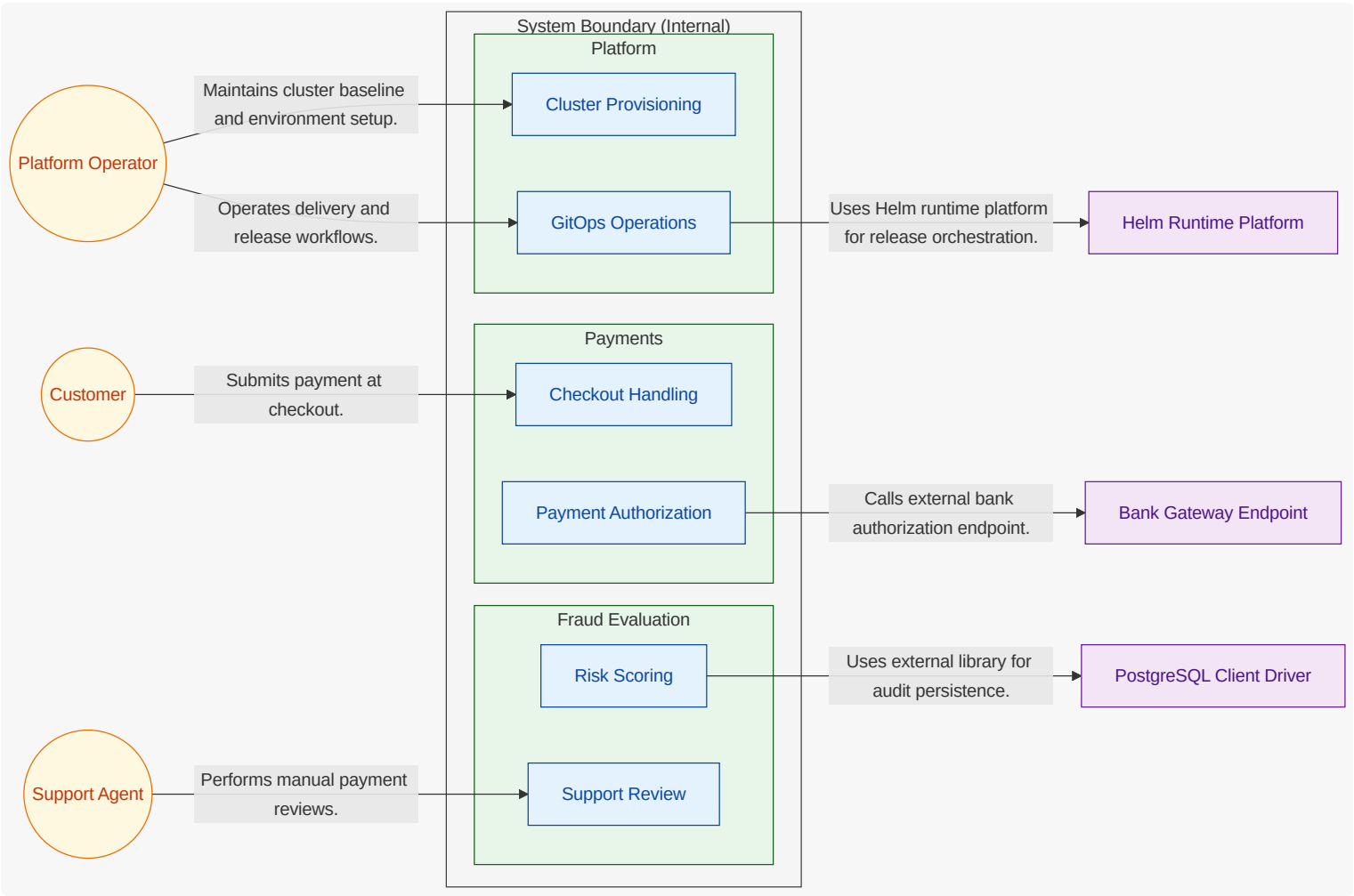
Show the stable authored architecture intent: capability areas, unit ownership boundaries, and intentional responsibility split.

6.1. What This View Answers

- What are the main capability areas?
- What are the stable units of responsibility and what does each unit own?
- How are responsibilities intentionally split?

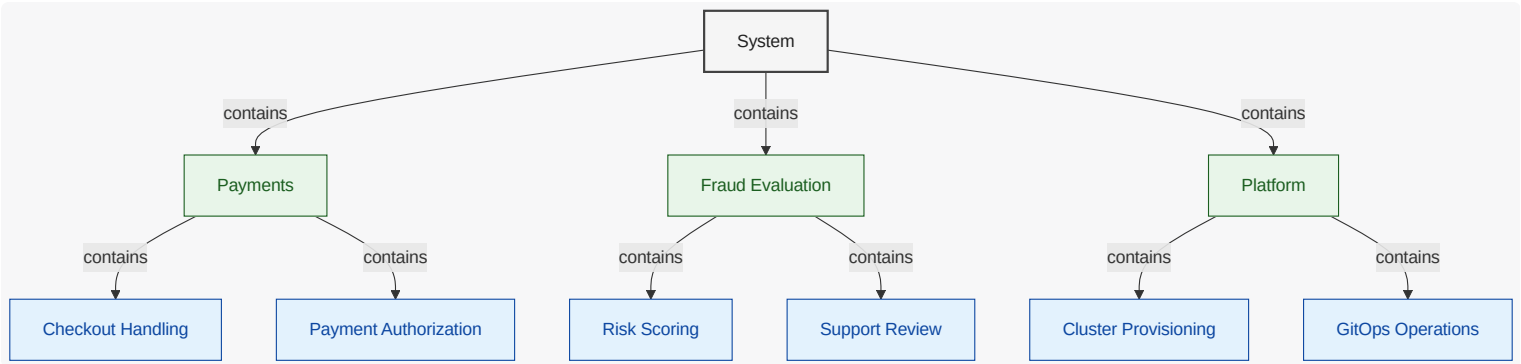
6.2. System Boundary Diagram

What this diagram shows: explicit internal vs external scope. Functional units are inside the System Boundary (Internal) container, while actors and referenced dependencies are shown outside the boundary.



6.3. System Decomposition Diagram

What this diagram shows: stable capability decomposition from functional groups into functional units.



6.4. Functional Group Manhattan Matrix

What this diagram shows: a table-like matrix where functional groups are the bottom row (columns) and functional units are arranged in rows above their owning group.

Checkout Handling	Risk Scoring	Cluster Provisioning
Payment Authorization	Support Review	GitOps Operations
Payments	Fraud Evaluation	Platform

6.5. Functional Groups and Units (View Scoped)

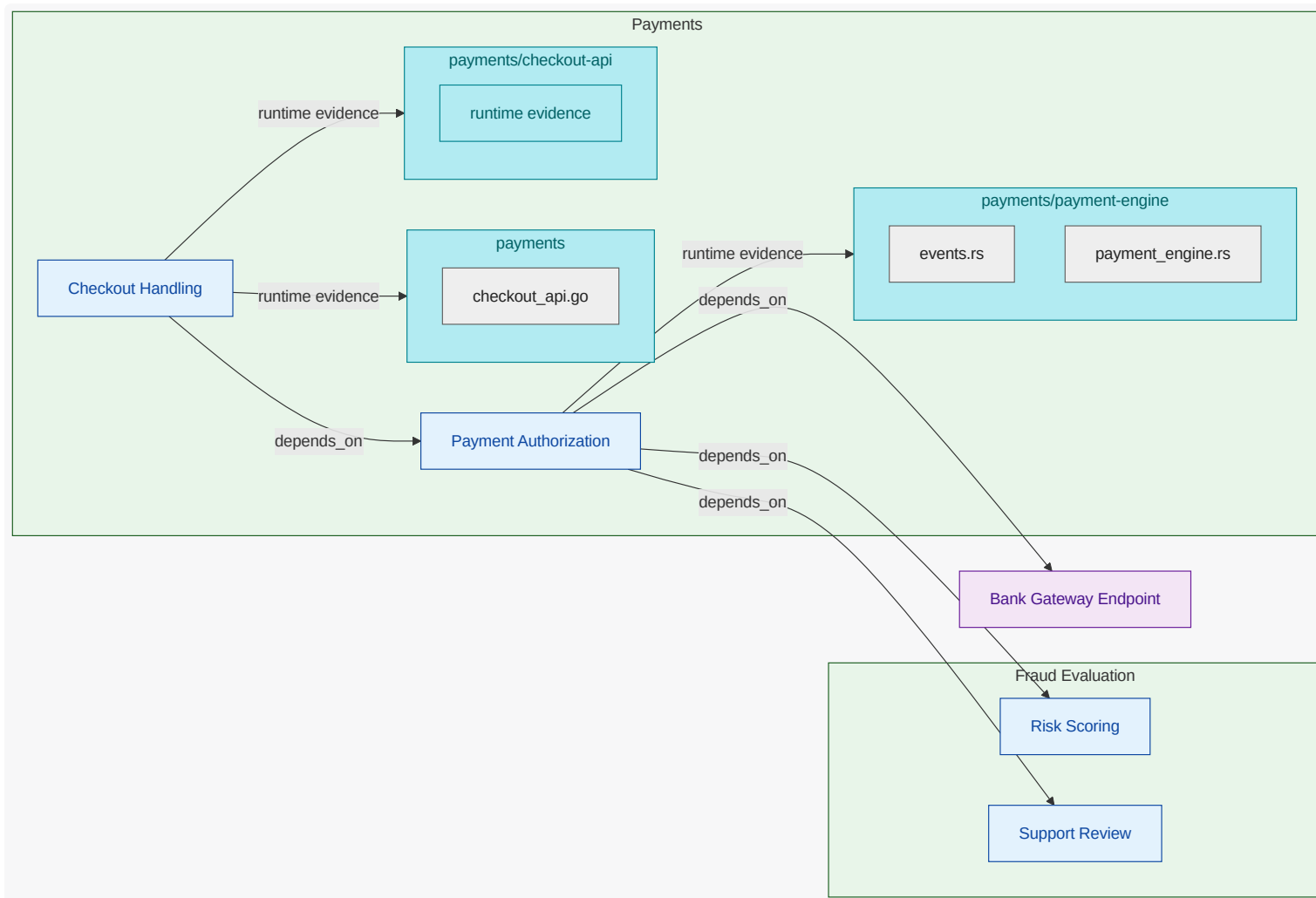
6.5.1. Payments (FG-PAYMENTS)

Core payment checkout and authorization domain.

The <<REF_IDX-CATALOG_FG_PAYMENTS,payments>> group defines the product-facing payment journey from user intent to final payment outcome. It owns the consistency of <<REF_IDX-CATALOG_ACT_CUSTOMER,customer>> messaging and transaction decisions when a payment is attempted, declined, retried, or temporarily unavailable. The group keeps <<REF_IDX-CATALOG_ACT_CUSTOMER,customer>> <<REF_IDX-ENGMODEL_TERM_FLOW,flow>> stable while depending on fraud and external bank capabilities.

Functional Unit Dependency Diagram

What this diagram shows: dependencies involving functional units in this functional group. Units in this group are rendered inside the group container; connected external units and referenced elements are shown outside it.



Checkout Handling (FU-CHECKOUT)

Checkout handling is the user-facing entrypoint where payment requests are initiated and normalized. It validates request shape, preserves transaction context, and returns clear customer feedback for each outcome. It delegates decision logic to payment authorization while protecting the user experience boundary.

Owned Responsibility

functional responsibility for checkout handling ; includes decision and orchestration flow to Payment Authorization

Key Collaborators

Payment Authorization

Linked Requirements

REQ-PAY-001 , REQ-PAY-003 , REQ-PAY-006 , REQ-PAY-007 , REQ-PAY-008

Payment Authorization (FU-PAYMENT-AUTHORIZATION)

Payment authorization orchestrates the final transaction decision path. It coordinates fraud scoring , external bank interactions, and escalation to support review when needed. The unit returns deterministic outcomes so downstream behavior remains consistent and testable.

Owned Responsibility

functional responsibility for payment authorization ; includes decision and orchestration flow to Bank Gateway Endpoint and decision and orchestration flow to Risk Scoring

Key Collaborators

Bank Gateway Endpoint , Risk Scoring , Support Review

Linked Requirements

REQ-PAY-001 , REQ-PAY-004 , REQ-PAY-006 , REQ-PAY-007 , REQ-PAY-009

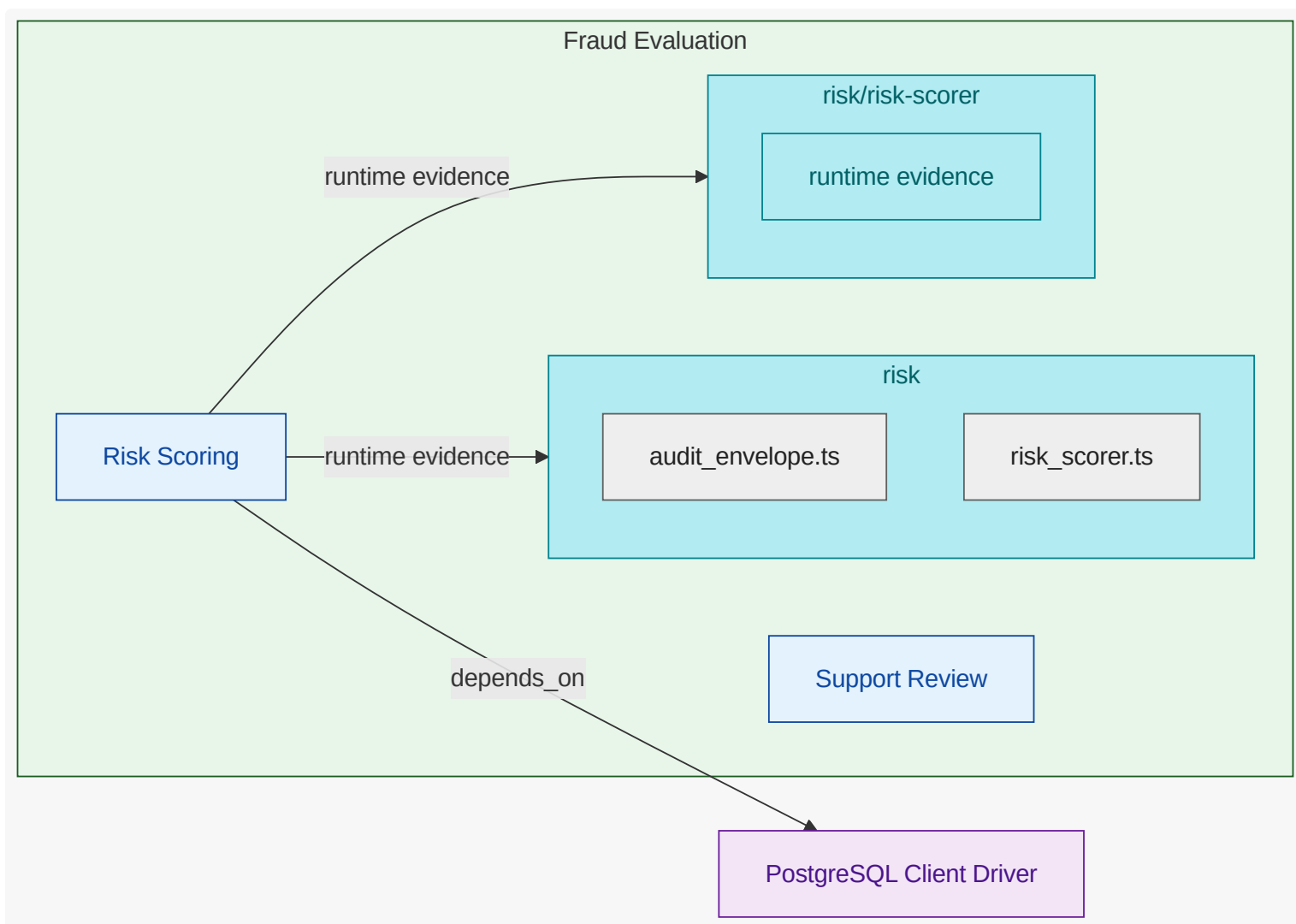
6.5.2. Fraud Evaluation (FG-FRAUD)

Risk scoring and fraud audit domain.

The <<REF_IDX-CATALOG_FG_FRAUD,fraud evaluation>> group exists to reduce unsafe approvals while preserving throughput for legitimate <<REF_IDX-CATALOG_FG_PAYMENTS,payments>>. It combines automated <<REF_IDX-CATALOG_FU_RISK_SCORING,risk scoring>> with manual <<REF_IDX-CATALOG_FU_SUPPORT_REVIEW,support review>> so uncertain transactions move through a controlled escalation path. The group ensures <<REF_IDX-ENGMODEL_TERM_RISK,risk>> decisions are explainable, auditable, and operationally actionable.

Functional Unit Dependency Diagram

What this diagram shows: dependencies involving functional units in this functional group. Units in this group are rendered inside the group container; connected external units and referenced elements are shown outside it.



Risk Scoring (FU-RISK-SCORING)

Risk scoring computes and classifies transaction **risk** before approval decisions are finalized. It provides a stable scoring contract to authorization and supports audit context for later analysis. The unit is focused on decision quality, consistency, and policy-driven classification behavior.

Owned Responsibility

functional responsibility for **risk scoring**; includes decision and orchestration **flow** to **PostgreSQL Client Driver**

Key Collaborators

PostgreSQL Client Driver

Linked Requirements

REQ-PAY-002, **REQ-PAY-005**

Support Review (FU-SUPPORT-REVIEW)

Support review handles manual decisions for escalated or ambiguous payment cases. It gives **support** operators context to approve, reject, or request additional verification in a controlled **flow**. The unit ensures manual intervention remains auditable, policy-constrained, and operationally reliable.

Owned Responsibility

functional responsibility for support review

Key Collaborators

none

Linked Requirements

REQ-PAY-004, REQ-PAY-009

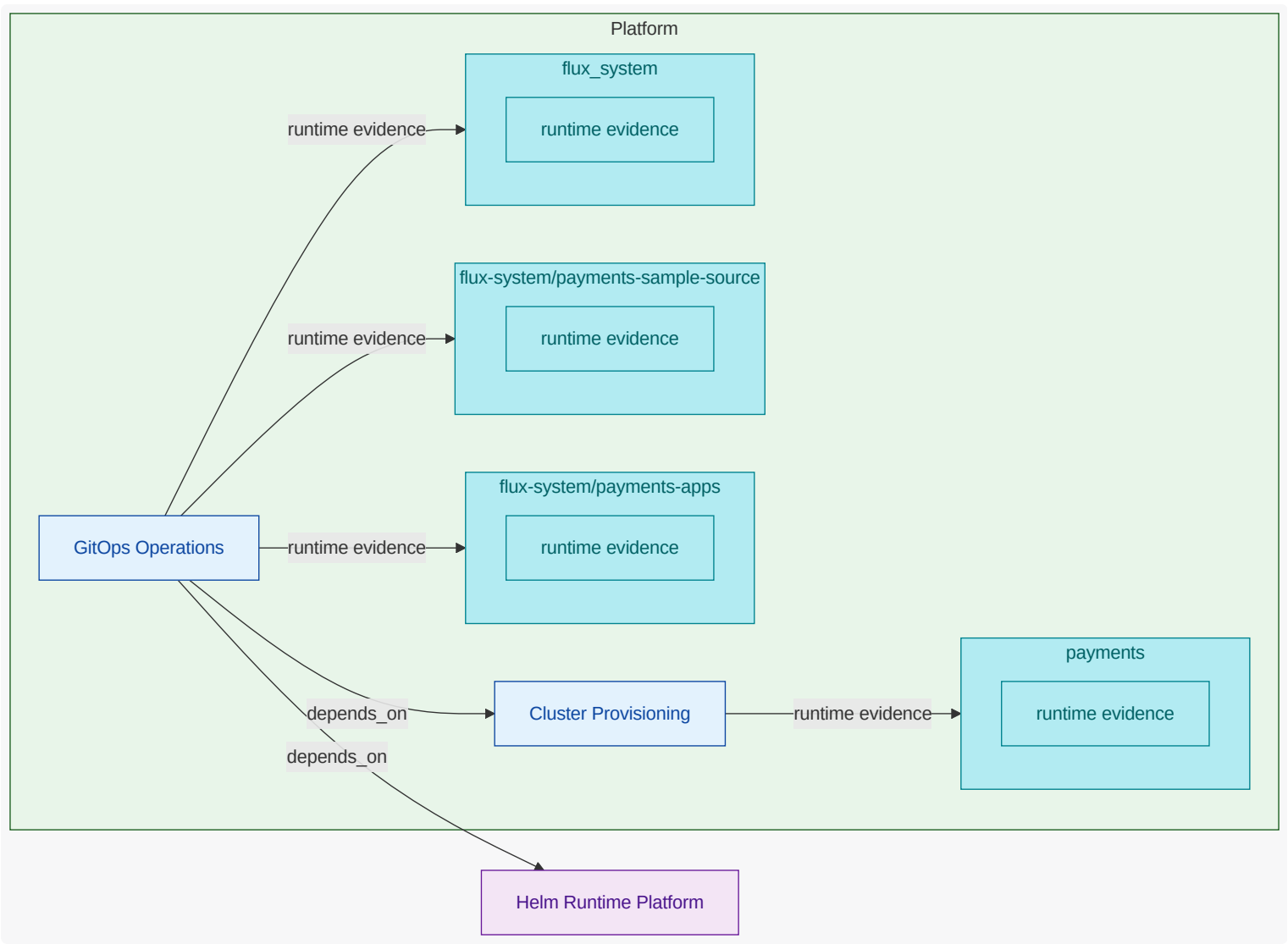
6.5.3. Platform (FG-PLATFORM)

Cluster provisioning and GitOps operations domain.

The <<REF_IDX-CATALOG_FG_PLATFORM,platform>> group provides the runtime and deployment foundation used by all product capabilities.
It owns environment provisioning, namespace and cluster boundaries, and continuous reconciliation behavior.
The group enables safe delivery and reliable operations without owning payment business logic.

Functional Unit Dependency Diagram

What this diagram shows: dependencies involving functional units in this functional group. Units in this group are rendered inside the group container; connected external units and referenced elements are shown outside it.



Cluster Provisioning (FU-CLUSTER-PROVISIONING)

Cluster provisioning creates the runtime substrate used by all application workloads. It establishes cluster and namespace structure, baseline controls, and environment-level readiness. This unit is responsible for predictable, repeatable infrastructure foundations.

Owned Responsibility

functional responsibility for cluster provisioning

Key Collaborators

none

Linked Requirements

no explicit authored requirement trigger

GitOps Operations (FU-GITOPS-OPERATIONS)

GitOps operations continuously reconciles intended release state with actual runtime state. It governs rollout flow, drift correction, and operational delivery confidence across payment and fraud workloads. The unit provides safe and observable release behavior as an ongoing operational capability.

Owned Responsibility

functional responsibility for gitops operations ; includes decision and orchestration flow to Cluster Provisioning and decision and orchestration flow to Helm Runtime Platform

Key Collaborators

Cluster Provisioning, Helm Runtime Platform

Linked Requirements

no explicit authored requirement trigger

7. Communication View

Show who communicates with whom across key request paths, including interface edges and dependency handoffs.

7.1. What This View Answers

- Who talks to whom and over which interfaces?
- Which edges are synchronous, asynchronous, event-driven, or callback-oriented?
- Which communication paths are critical to the main request flow?

7.2. Coverage Gaps

Coverage summary: 3/4 units have direct evidence coverage in this view.

- Support Review has no direct inferred runtime/deployment evidence yet.

7.3. Recommended Next Evidence Additions

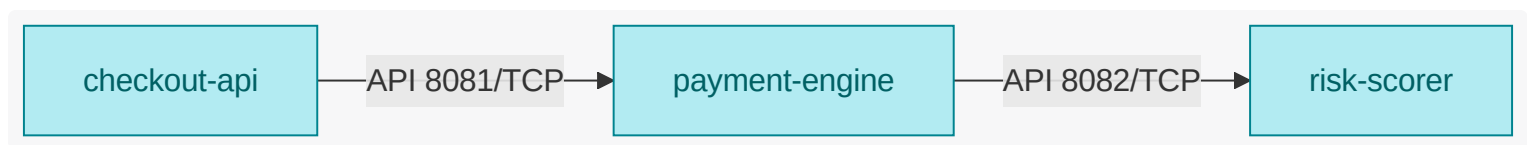
- Add explicit communication metadata (protocol, sync/async/event/callback) to authored mappings where currently implicit.
- Expose service protocol/port metadata in Helm or manifest values to enrich interface-edge inference.
- Capture missing communicating runtime units by adding discoverable workload artifacts under scanned inference roots.

7.4. Communication Path Graph

What this diagram shows: inferred unit-to-unit request/call flow, including available interface/port labels.

NOTE

This graph is inferred from available deployment/runtime artifacts and may be partial. Missing edges or interface details indicate missing derived communication evidence, not necessarily missing behavior.



7.5. Functional Groups and Units (View Scoped)

8. Deployment View

Show inferred deployment artifacts and ownership mapping to authored units. This view emphasizes deployment relationships and platform operations.

8.1. What This View Answers

- How does authored intent become deployed runtime?
- What control-plane objects manage deployable units?
- Where are platform ownership boundaries and missing ownership signals?

8.2. Coverage Gaps

Coverage summary: 5/6 units have direct evidence coverage in this view.

- Support Review has no direct inferred runtime/deployment evidence yet.

8.3. Recommended Next Evidence Additions

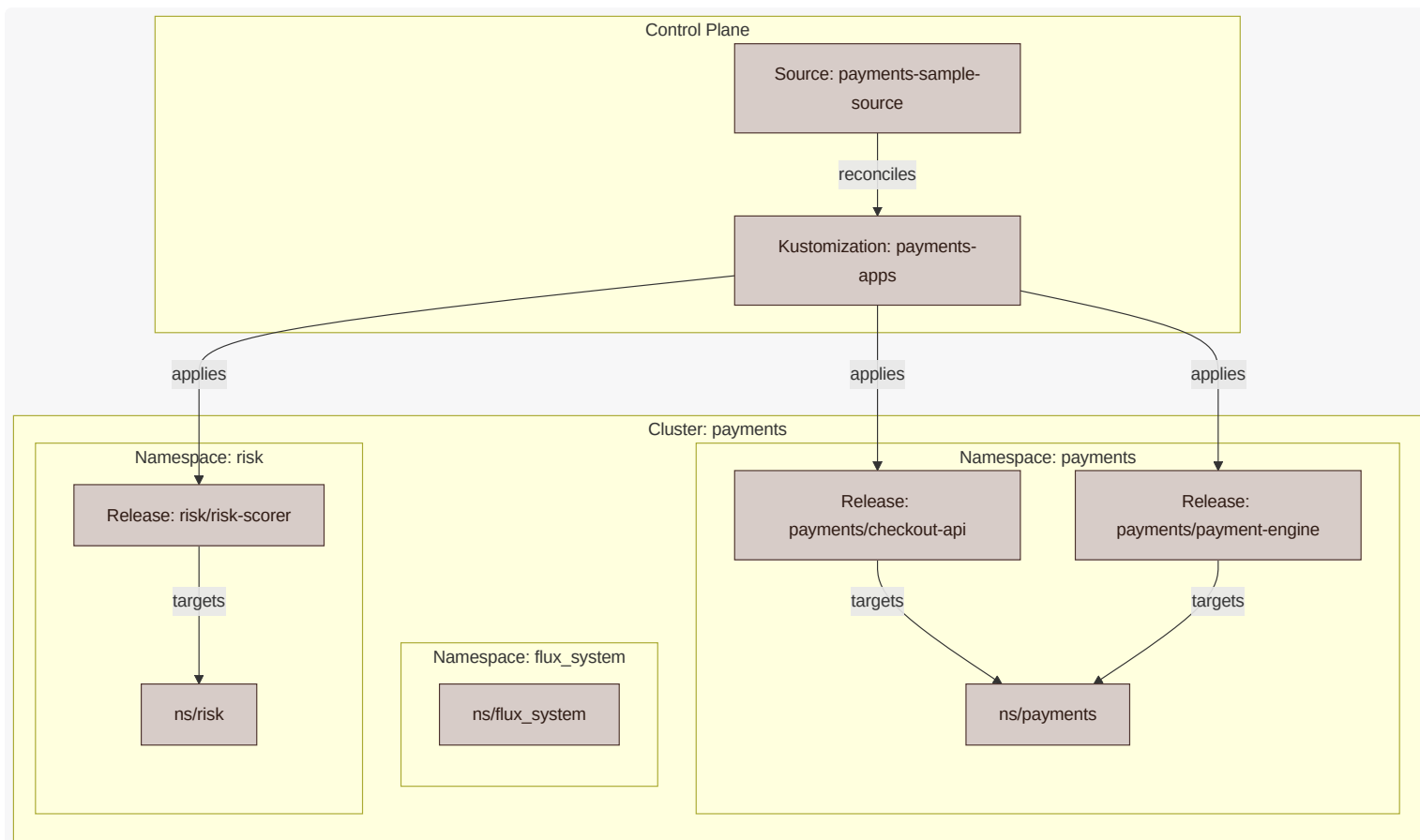
- Add owner metadata to Flux/Kustomization/ Helm objects for clearer platform ownership mapping.
- Ensure deployment control artifacts (source, kustomization, release) are all included in scanned directories.
- Add deterministic naming conventions for release and namespace objects to improve cross-artifact linking.

8.4. Deployment Artifact Relationship Graph

What this diagram shows: how source/control-plane artifacts connect to releases, namespaces, workloads, and target cluster context.

NOTE

This graph is inferred from available deployment artifacts (for example Terraform, Flux, Helm) and may be partial when source metadata is incomplete. Namespace and cluster boundaries are rendered as containers when target/placement relationships are inferred. Node labels include role hints (for example Source , Kustomization , Release , Workload , ns/...) to distinguish similarly named elements.

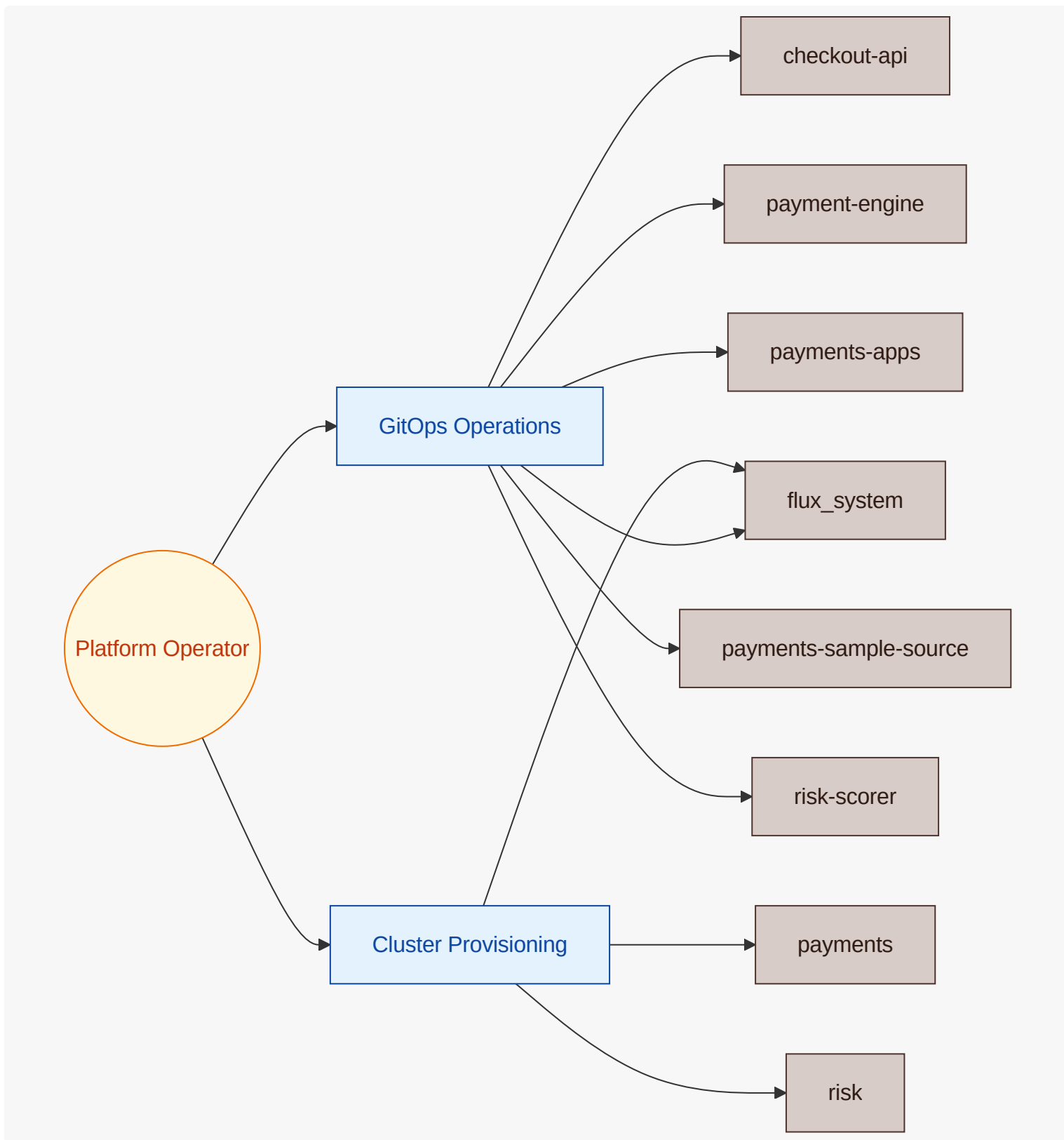


8.5. Platform Operations Graph

What this diagram shows: which platform actors operate which platform units and the control-plane targets they influence.

NOTE

Platform operations links are inferred from authored actor mappings plus discovered deployment control-plane artifacts.



8.6. Functional Groups and Units (View Scoped)

8.6.1. Payments (FG-PAYMENTS)

`payments` is deployed so `checkout` and authorization can roll independently with minimal blast radius. Deployment design prioritizes safe promotion, fast rollback, and dependency readiness checks before policy-impacting releases are exposed.

Checkout Handling (FU-CHECKOUT)

Checkout Handling Deployment Design

checkout handling is released independently to protect user-facing velocity without destabilizing policy logic. Deployment design favors fast rollback and compatibility checks with the current authorization interface .

Deployment Aspect	View-Scoped Detail
Deployment trigger context	REQ-PAY-001 , REQ-PAY-003 , REQ-PAY-006 , REQ-PAY-007 , REQ-PAY-008
Deployment dependencies	Payment Authorization
Inferred deployment evidence	runtime: payments , payments/checkout-api

Payment Authorization (FU-PAYMENT-AUTHORIZATION)

Payment Authorization Deployment Design

payment authorization deployment is policy-sensitive and therefore rollout-cautious. Releases should stage gradually, verify dependency health, and preserve in-flight transaction continuity.

Deployment Aspect	View-Scoped Detail
Deployment trigger context	REQ-PAY-001 , REQ-PAY-004 , REQ-PAY-006 , REQ-PAY-007 , REQ-PAY-009
Deployment dependencies	Bank Gateway Endpoint , Risk Scoring , Support Review
Inferred deployment evidence	runtime: payments/payment-engine

8.6.2. Fraud Evaluation (FG-FRAUD)

fraud evaluation deployment is tuned for cautious rollout because scoring changes can alter approval rates. Deployment design favors staged promotions and rapid monitoring of scoring outcomes before wider exposure.

Risk Scoring (FU-RISK-SCORING)

Risk Scoring Deployment Design

risk scoring deployment uses staged rollout because scoring changes have immediate decision impact. Deployment design includes observation windows for score distribution and escalation-rate changes.

Deployment Aspect	View-Scoped Detail
Deployment trigger context	REQ-PAY-002 , REQ-PAY-005
Deployment dependencies	PostgreSQL Client Driver
Inferred deployment evidence	runtime: risk , risk/risk-scorer

Support Review (FU-SUPPORT-REVIEW)

Support Review Deployment Design

support review deployment isolates privileged workflows from public ingress components. Deployment design must preserve active review sessions across upgrades and ensure queue/review latency visibility.

Deployment Aspect	View-Scoped Detail
Deployment trigger context	REQ-PAY-004 , REQ-PAY-009
Deployment dependencies	none
Inferred deployment evidence	authored unit with no direct derived runtime/code evidence yet

8.6.3. Platform (FG-PLATFORM)

platform deployment design governs how infrastructure intent is applied and kept in sync over time. It prioritizes deterministic sequencing, drift control , and recoverable change paths before application teams depend on new platform states .

Cluster Provisioning (FU-CLUSTER-PROVISIONING)

Cluster Provisioning Deployment Design

cluster provisioning deployment is infrastructure-first and sequence-sensitive. Deployment design requires deterministic change plans, drift awareness, and rollback strategy before apply.

Deployment Aspect	View-Scoped Detail
Deployment trigger context	no explicit authored requirement trigger
Deployment dependencies	none
Inferred deployment evidence	runtime: payments

GitOps Operations (FU-GITOPS-OPERATIONS)

GitOps Operations Deployment Design

gitops operations deployment defines the release control plane for application artifacts. Deployment design prioritizes policy gates, controlled promotion, and resilient rollback mechanics.

Deployment Aspect	View-Scoped Detail
Deployment trigger context	no explicit authored requirement trigger
Deployment dependencies	Cluster Provisioning , Helm Runtime Platform
Inferred deployment evidence	runtime: flux-system/payments-apps , flux-system/payments-sample-source , flux_system

9. Security View

Show inferred exposure and dependency risk points aligned to unit boundaries, focused on attack paths and security evidence .

9.1. What This View Answers

- What are the main trust boundaries and attack paths?
- Which units are exposed and what security evidence exists?
- Where is the threat model incomplete?

9.2. Coverage Gaps

Coverage summary: 4/4 units have direct evidence coverage in this view .

- No major coverage gaps detected from current authored and inferred inputs.

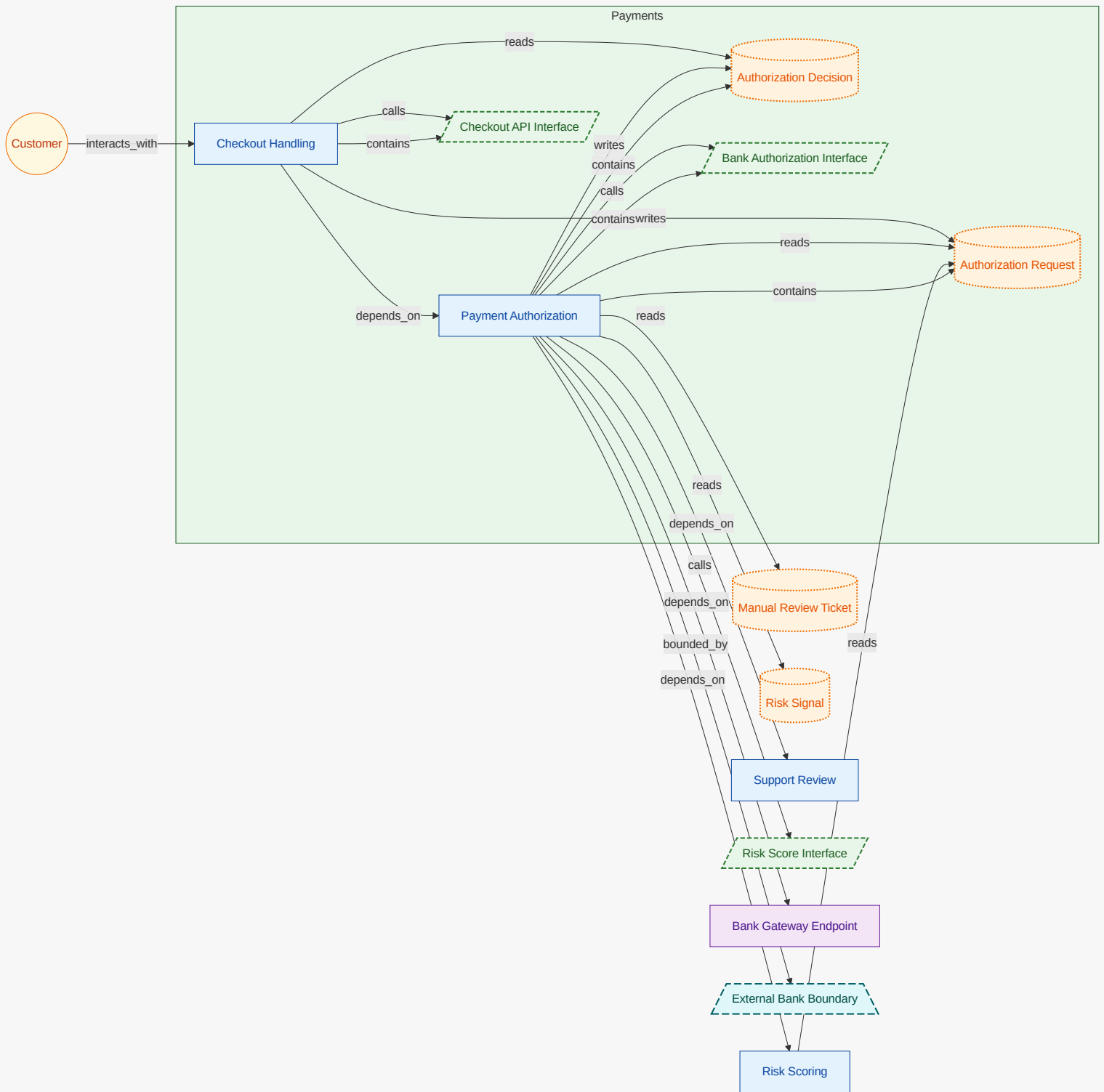
9.3. Recommended Next Evidence Additions

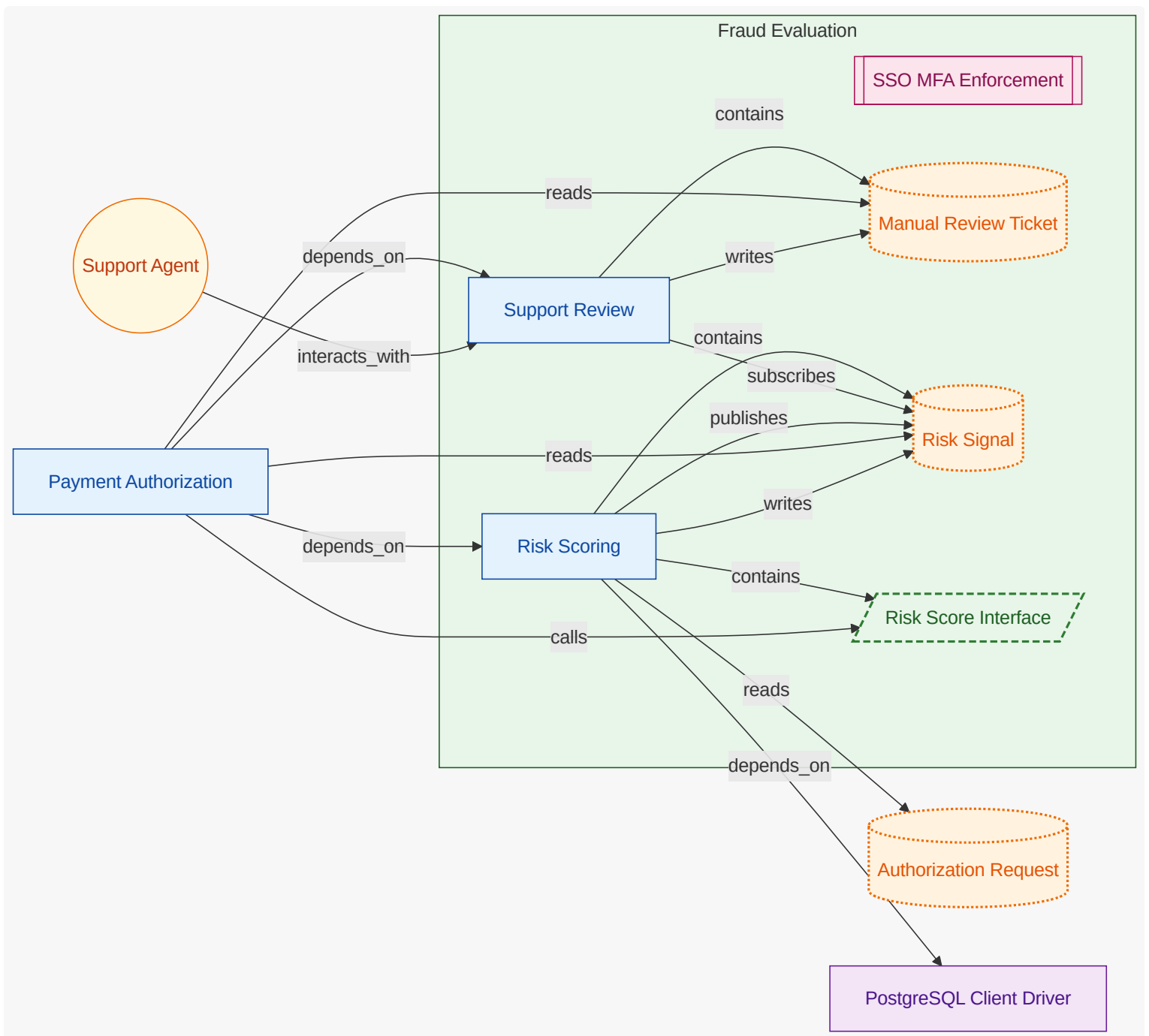
- No immediate evidence additions are required for this view .

9.4. Threat Model Context Diagram

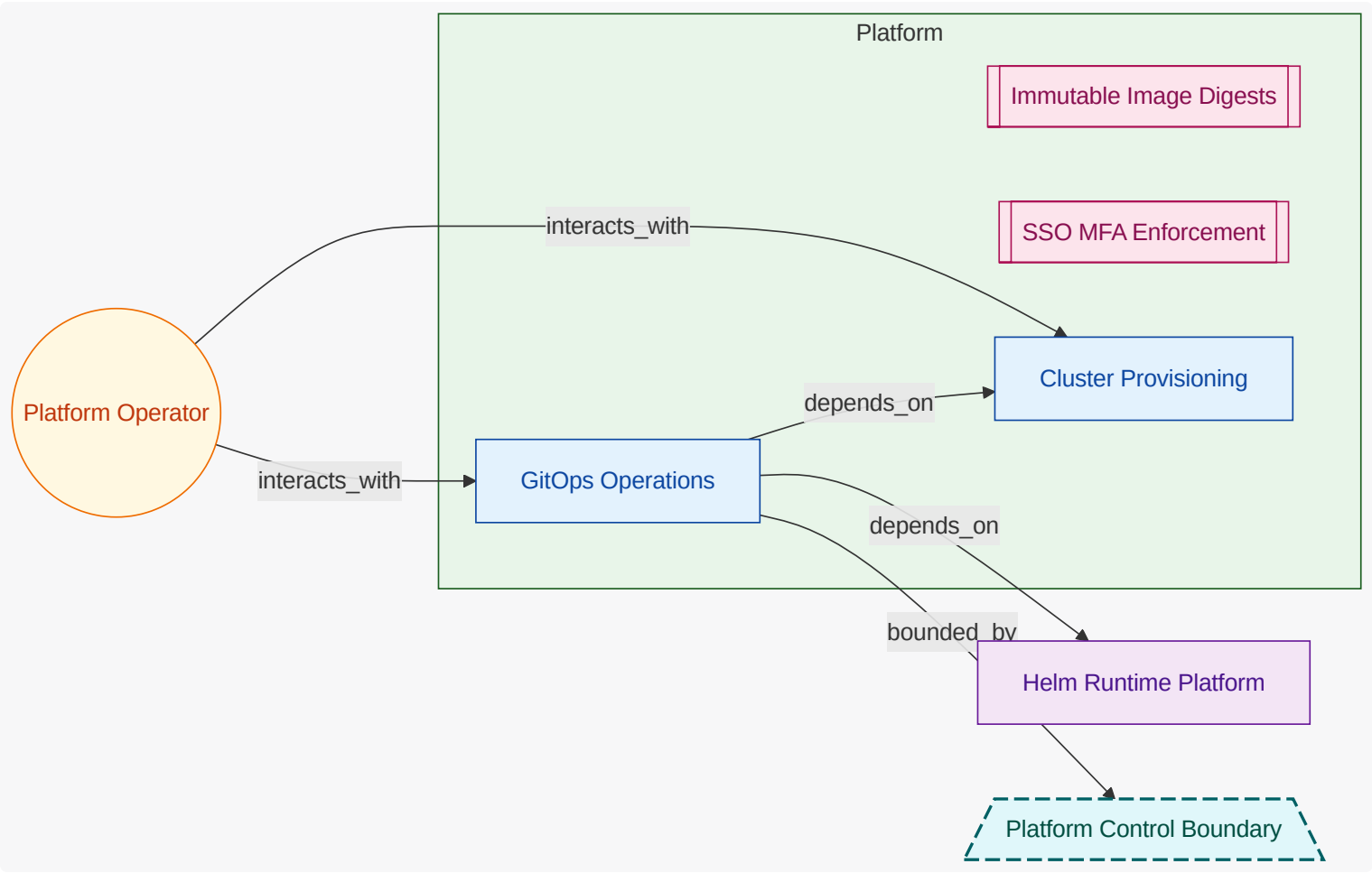
What these diagrams show: OWASP-style context views split by functional group. Each group diagram keeps owned functional units and owned security-relevant entities inside the functional-group container; connected actors, referenced elements, external functional units, and other external entities are rendered outside it.

9.4.1. Payments (FG-PAYMENTS)





9.4.3. Platform (FG-PLATFORM)



9.5. Threat Scenario Register

9.5.1. Manual review ticket tampering influences authorization result (TS-PAYMENTS-RISK-TICKET-TAMPER)

A compromised support or workflow path modifies review ticket outcomes before authorization completes.

Field	Value
Status	identified
Owner	Platform Operator
Attack Vector	Fraudulent Transaction Pattern
Scope	Manual Review Ticket , Payment Authorization , Support Review
Flows	High-Risk Manual Review Flow
Likelihood	low
Impact	high
Severity	medium
Risk	RISK-PAYMENTS-MANUAL-REVIEW-TAMPER

Field	Value
Controls	SSO MFA Enforcement
Mitigations	MIT-PAYMENTS-MANUAL-REVIEW-AUDIT
Verifications	CV-PAYMENTS-MANUAL-REVIEW-TRACE
Operational Notes	Track closure through mitigation and verification linkage.

Control Verification Status

CV-PAYMENTS-MANUAL-REVIEW-TRACE

Field	Value
Control	SSO MFA Enforcement
Method	analysis
Status	partial
Owner	Platform Operator
Last Tested	2026-04-20
Risks	RISK-PAYMENTS-MANUAL-REVIEW-TAMPER
Findings	review ticket mutation trail exists but immutability controls are incomplete

9.5.2. Replayed bank callback triggers duplicate authorization transition (TS-PAYMENTS-BANK-CALLBACK-REPLAY)

Replayed callback message tries to overwrite or duplicate prior decision outcomes.

Field	Value
Status	mitigating
Owner	Platform Operator
Attack Vector	Replayed Authorization Callback
Scope	Authorization Decision , Bank Authorization Interface , Payment Authorization
Flows	Customer Checkout Authorization Flow
Likelihood	medium
Impact	high
Severity	high

Field	Value
Risk	RISK-PAYMENTS-BANK-CALLBACK-REPLAY
Controls	Callback Nonce and Idempotency Guard
Mitigations	MIT-PAYMENTS-CALLBACK-NONCE-CHECK
Verifications	CV-PAYMENTS-CALLBACK-REPLAY-TEST
Operational Notes	Track closure through mitigation and verification linkage.

Control Verification Status

CV-PAYMENTS-CALLBACK-REPLAY-TEST

Field	Value
Control	Callback Nonce and Idempotency Guard
Method	test
Status	pass
Owner	Platform Operator
Last Tested	2026-04-15
Risks	RISK-PAYMENTS-BANK-CALLBACK-REPLAY
Findings	duplicate callback identifiers correctly rejected

9.5.3. Checkout payload spoofing bypasses normalization checks (TS-PAYMENTS-CHECKOUT-SPOOFING)

Crafted payload shape attempts to force ambiguous authorization behavior and bypass policy checks.

Field	Value
Status	mitigating
Owner	Platform Operator
Attack Vector	Malicious API Request
Scope	Authorization Request , Checkout API Interface , Checkout Handling
Flows	Customer Checkout Authorization Flow
Likelihood	medium
Impact	high

Field	Value
Severity	high
Risk	RISK-PAYMENTS-CHECKOUT-SPOOFING
Controls	SSO MFA Enforcement
Mitigations	MIT-PAYMENTS-CHECKOUT-STRICT-SCHEMA
Verifications	CV-PAYMENTS-CHECKOUT-SCHEMA-TEST
Operational Notes	Track closure through mitigation and verification linkage.

Control Verification Status

CV-PAYMENTS-CHECKOUT-SCHEMA-TEST

Field	Value
Control	SSO MFA Enforcement
Method	test
Status	pass
Owner	Platform Operator
Last Tested	2026-04-10
Risks	RISK-PAYMENTS-CHECKOUT-SPOOFING
Findings	malformed checkout payloads rejected with deterministic decline path

9.6. Threat Mitigation Coverage

ID	Threat Scenario	Control	Status	Effectiveness	Owner	Verification Links	Notes
MIT-PAYMENTS-CALLBACK-NONCE-CHECK	TS-PAYMENTS-BANK-CALLBACK-REPLAY	Callback Nonce and Idempotency Guard	verified	high	Platform Operator	CV-PAYMENTS-CALLBACK-REPLAY-TEST	Nonce freshness and idempotency lock reduce replay acceptance probability.

ID	Threat Scenario	Control	Status	Effectiveness	Owner	Verification Links	Notes
MIT-PAYMENTS-CHECKOUT-STRICT-SCHEMA	TS-PAYMENTS-CHECKOUT-SPOOFING	SSO MFA Enforcement	implemented	medium	Platform Operator	CV-PAYMENTS-CHECKOUT-SCHEMA-TEST	Strict schema decoding and normalized request construction reduce spoofing surface.
MIT-PAYMENTS-MANUAL-REVIEW-AUDIT	TS-PAYMENTS-RISK-TICKET-TAMPER	SSO MFA Enforcement	partial	medium	Platform Operator	CV-PAYMENTS-MANUAL-REVIEW-TRACE	MFA-gated support actions are in place; append-only integrity controls are being expanded.

9.7. Security Flow Semantics

ID	Title	Kind	Direction	Frequency	Source	Destination	Protocol
FLOW-CUSTOMER-CHECKOUT	Customer Checkout Authorization Flow	security	inbound	realtime	Customer	Checkout Handling	https
FLOW-PAYMENTS-MANUAL-REVIEW	High-Risk Manual Review Flow	control	internal	on-demand	Risk Scoring	Support Review	internal-event

ID	Auth	Encryption	Integrity	Boundary Crossing	Trust Boundary	Threats	Data
FLOW-CUSTOMER-CHECKOUT	session-token	tls1.3	request-signature	true	External Bank Boundary	TS-PAYMENTS-BANK-CALLBACK-REPLAY, TS-PAYMENTS-CHECKOUT-SPOOFING	Authorization Decision , Authorization Request

ID	Auth	Encryption	Integrity	Boundary Crossing	Trust Boundary	Threats	Data
FLOW-PAYMENTS-MANUAL-REVIEW	workload-identity	tls1.3	signed-event	false	none	TS-PAYMENTS-RISK-TICKET-TAMPER	Manual Review Ticket, Risk Signal

9.8. Threat Assumptions

ID	Title	Status	Owner	Applies To	Rationale
ASM-PAYMENTS-BANK-SIGNING-VALID	Bank callback signatures are managed securely	accepted	Platform Operator	Bank Authorization Interface, External Bank Boundary, Payment Authorization	Contractual controls and quarterly partner assurance reviews support this assumption.

9.9. Threat Model Out-of-Scope Decisions

ID	Title	Status	Owner	Applies To	Expires On	Reason
OOS-PAYMENTS-BANK-HSM-OPERATIONS	Bank partner HSM internals	approved	Platform Operator	Bank Gateway Endpoint, External Bank Boundary	2027-12-31	Key management implementation details within the partner bank infrastructure are not accessible to this team.
OOS-PAYMENTS-SI-10-LOW-BASELINE	Callback nonce control outside NIST 800-53 Low profile	approved	Platform Operator	Bank Authorization Interface, Callback Nonce and Idempotency Guard, Payment Authorization	2027-12-31	SI-10 input validation is retained as a local protocol-integrity control, but it is not selected by the NIST SP 800-53 Rev. 5 Low baseline profile used by this sample.

9.10. Security Logging and Observability

Signal	Layer	Owner	Evidence
application security telemetry hooks	code	FU-RISK-SCORING	code support/audit_envelope.ts
fraud and abuse detection code paths	code	FU-RISK-SCORING	code risk_scorer.ts

Signal	Layer	Owner	Evidence
deployment and platform audit events	deployment	FU-CHECKOUT	helmrelease checkout-api
deployment and platform audit events	deployment	FU-CHECKOUT	namespace payments
deployment and platform audit events	deployment	FU-CLUSTER-PROVISIONING	cluster payments
deployment and platform audit events	deployment	FU-GITOPS-OPERATIONS	gitrepository payments-sample-source
deployment and platform audit events	deployment	FU-GITOPS-OPERATIONS	kustomization payments-apps
deployment and platform audit events	deployment	FU-GITOPS-OPERATIONS	namespace flux_system
deployment and platform audit events	deployment	FU-PAYMENT-AUTHORIZATION	helmrelease payment-engine
deployment and platform audit events	deployment	FU-RISK-SCORING	helmrelease risk-scorer
deployment and platform audit events	deployment	FU-RISK-SCORING	namespace risk
abuse and fraud decision logs	runtime	FU-RISK-SCORING	helmrelease risk-scorer
abuse and fraud decision logs	runtime	FU-RISK-SCORING	namespace risk

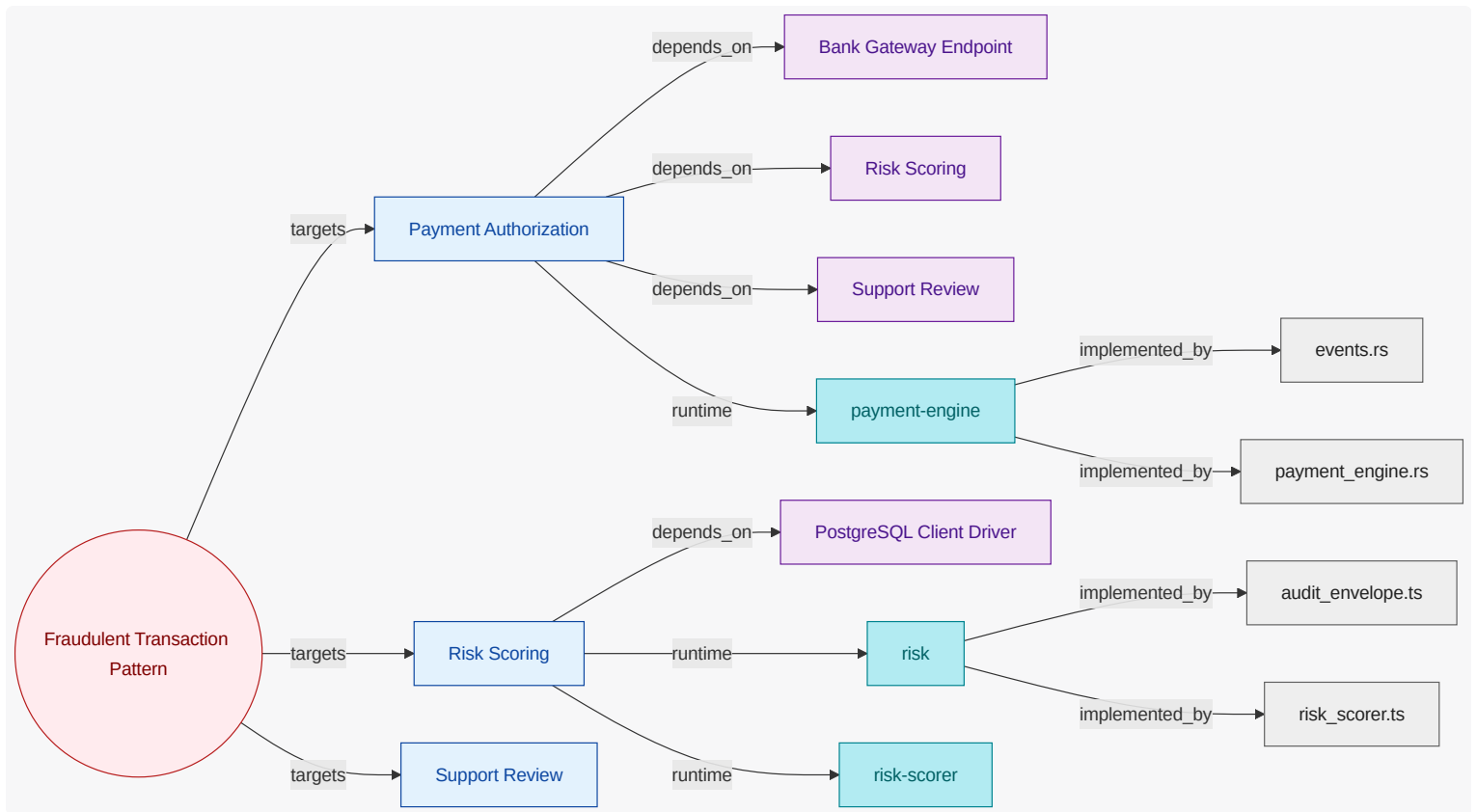
9.11. Attack Vector Chapters

9.11.1. Fraudulent Transaction Pattern (AV-FRAUDULENT-TRANSACTION-PATTERN)

Coordinated abuse pattern using synthetic identities, stolen instruments, and velocity anomalies to seek unauthorized approvals.

Mitigated by: none

Trust boundaries: External Bank Boundary



Payment Authorization (FU-PAYMENT-AUTHORIZATION)

payment authorization security protects decision integrity and callback integrity. The design defends against replay, policy probing, and ambiguous error channels that could be abused.

Attack Surface

Bank Gateway Endpoint , Risk Scoring , Support Review

Security Evidence Present

runtime: payments/payment-engine | code modules: domain, payment_engine

Risk Scoring (FU-RISK-SCORING)

risk scoring security assumes adversarial input attempts and model manipulation pressure. Design controls enforce strict input handling and evidence capture for post-event investigation.

Attack Surface

PostgreSQL Client Driver

Security Evidence Present

runtime: risk , risk/risk-scorer | code modules: risk_scorer , support

Support Review (FU-SUPPORT-REVIEW)

support review security requires strong operator identity controls and tamper-evident audit trails. The design prevents silent overrides and guarantees every manual decision is attributable.

Attack Surface

none

Security Evidence Present

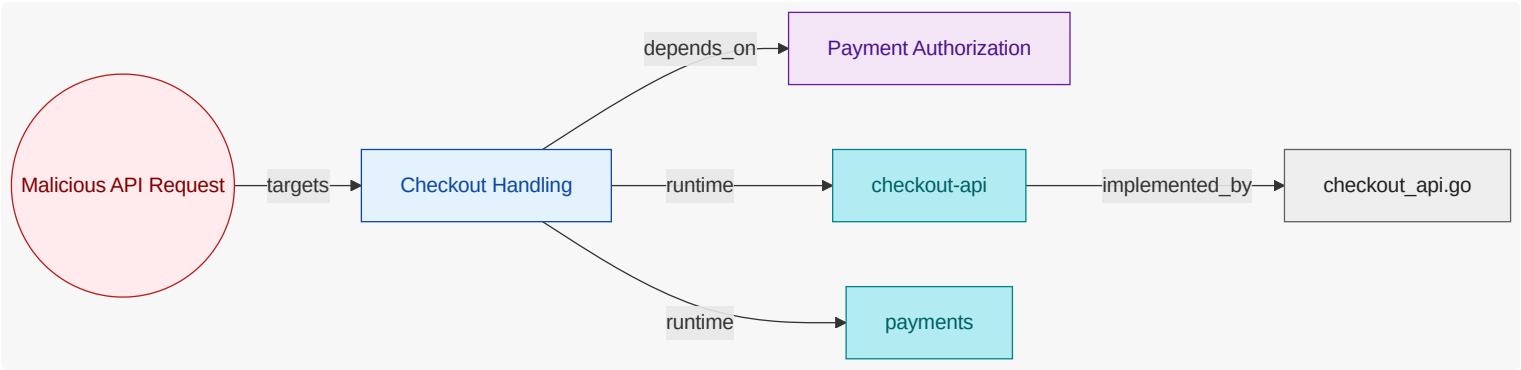
authored unit with no direct derived runtime/code evidence yet

9.11.2. Malicious API Request (AV-MALICIOUS-API-REQUEST)

Crafted payloads attempting to bypass authorization controls.

Mitigated by: SSO MFA Enforcement

Trust boundaries: none



Checkout Handling (FU-CHECKOUT)

checkout handling security protects the internet-facing ingress. The design requires strict validation, abuse resistance, and traceable rejection behavior so malicious inputs are contained without harming legitimate customer flows.

Attack Surface

Payment Authorization

Security Evidence Present

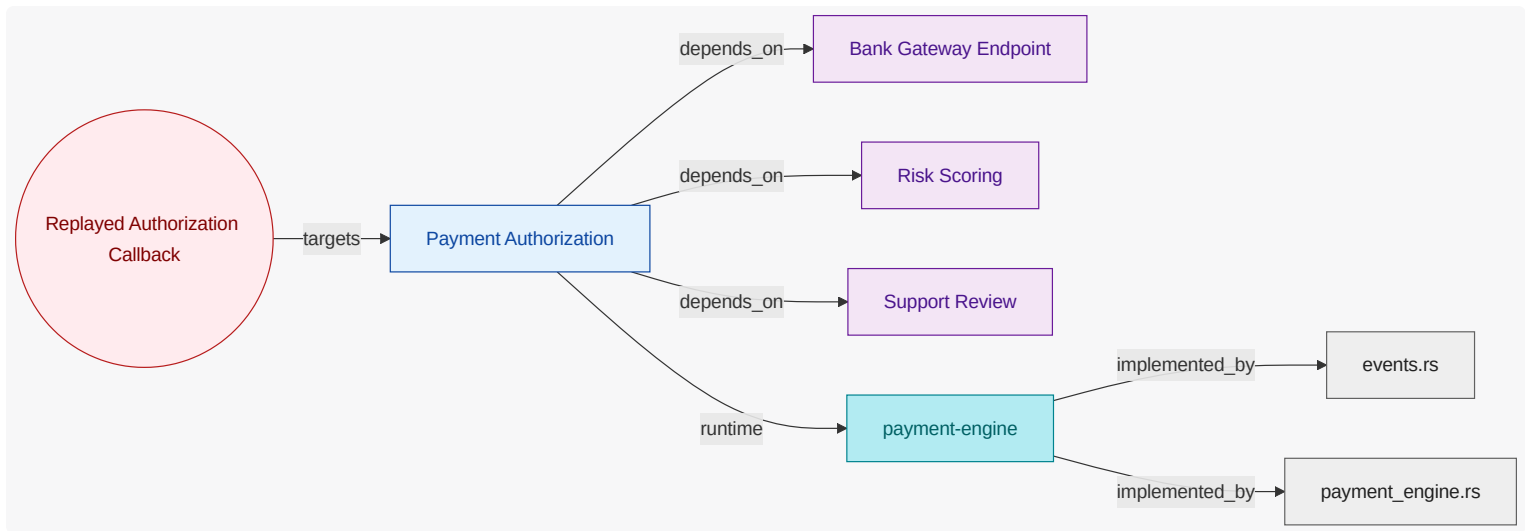
runtime: payments, payments/checkout-api | code modules: checkout_api

9.11.3. Replayed Authorization Callback (AV-REPLAYED-AUTH-CALLBACK)

Replay attack against external authorization callback flow.

Mitigated by: none

Trust boundaries: External Bank Boundary



Payment Authorization (FU-PAYMENT-AUTHORIZATION)

payment authorization security protects decision integrity and callback integrity. The design defends against replay, policy probing, and ambiguous error channels that could be abused.

Attack Surface

Bank Gateway Endpoint, Risk Scoring, Support Review

Security Evidence Present

runtime: payments/payment-engine | code modules: domain, payment_engine

10. Traceability View

Show requirement-to-unit-to-evidence traceability, including coverage confidence and explicit evidence gaps.

10.1. What This View Answers

- Which requirements map to which units?
- Which authored units have runtime/code evidence and which do not?
- Where are confidence or completeness gaps in trace coverage?

10.2. Coverage Gaps

Coverage summary: 5/6 units have direct evidence coverage in this view.

- Cluster Provisioning has no direct inferred code evidence yet.
- GitOps Operations has no direct inferred code evidence yet.
- Support Review has no direct inferred code evidence yet.
- Support Review has no direct inferred runtime evidence yet.

10.3. Recommended Next Evidence Additions

- Add explicit requirement-to-owner mappings where requirement scope is currently broad or ambiguous.
- Add ownership annotations for runtime and code artifacts where coverage is still unresolved.
- Prioritize closing gaps for units that are authored but lack both runtime and code evidence.

11. State Lifecycle View

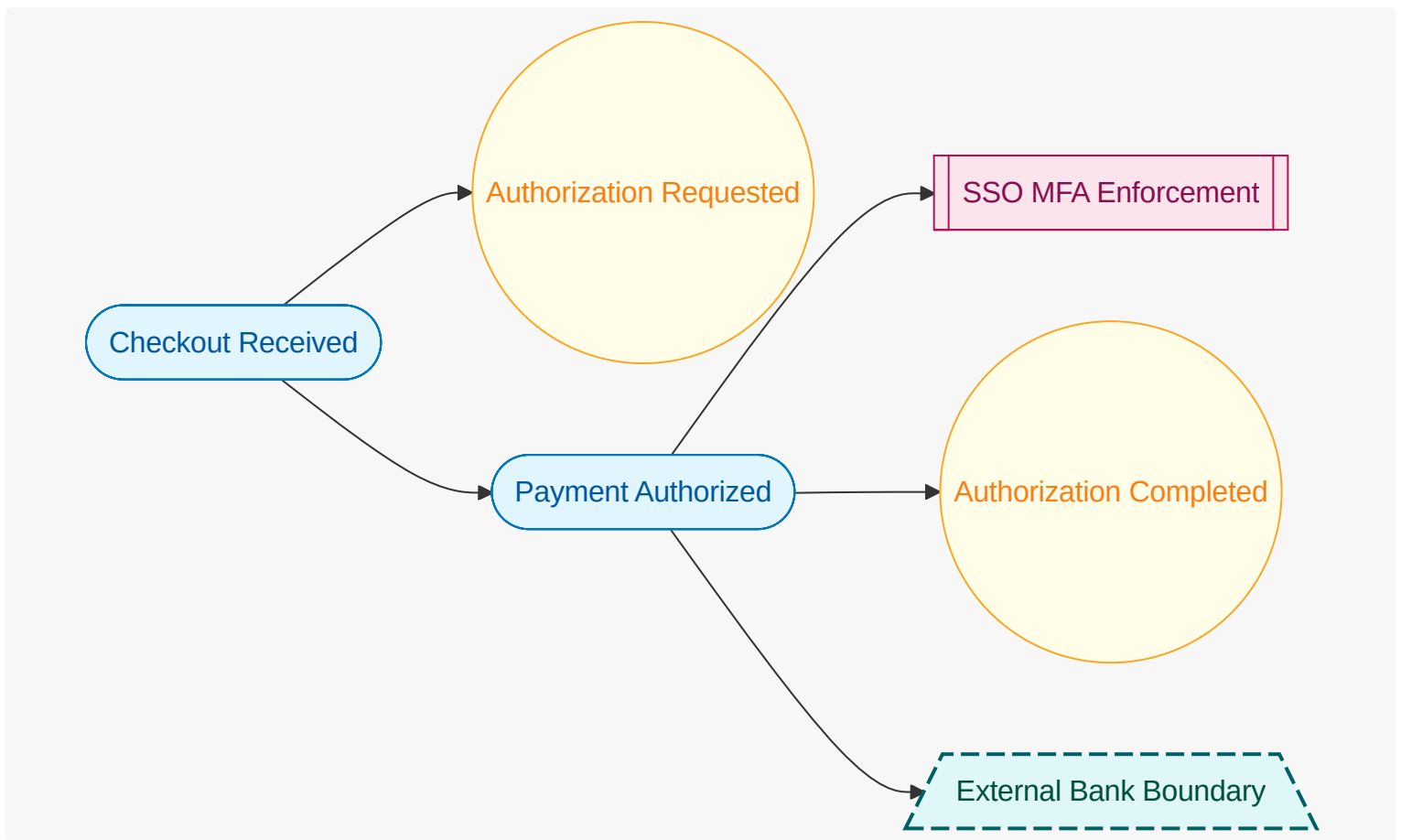
Show workflow state transitions, ownership of transitions, and key exceptional paths.

11.1. What This View Answers

- What states exist and which events trigger transitions?
- Which unit owns each state transition?
- Where do automatic and manual flows diverge?

11.2. State Lifecycle Diagram

What this diagram shows: authored lifecycle states, triggering events, guard controls, trust boundaries, and lifecycle transitions for this view.



11.3. Coverage Gaps

Coverage summary: No functional units are in scope for this view.

- No major coverage gaps detected from current authored and inferred inputs.

11.4. Recommended Next Evidence Additions

- No immediate evidence additions are required for this view.

11.5. Functional Groups and Units (View Scoped)

12. Interaction Flow View

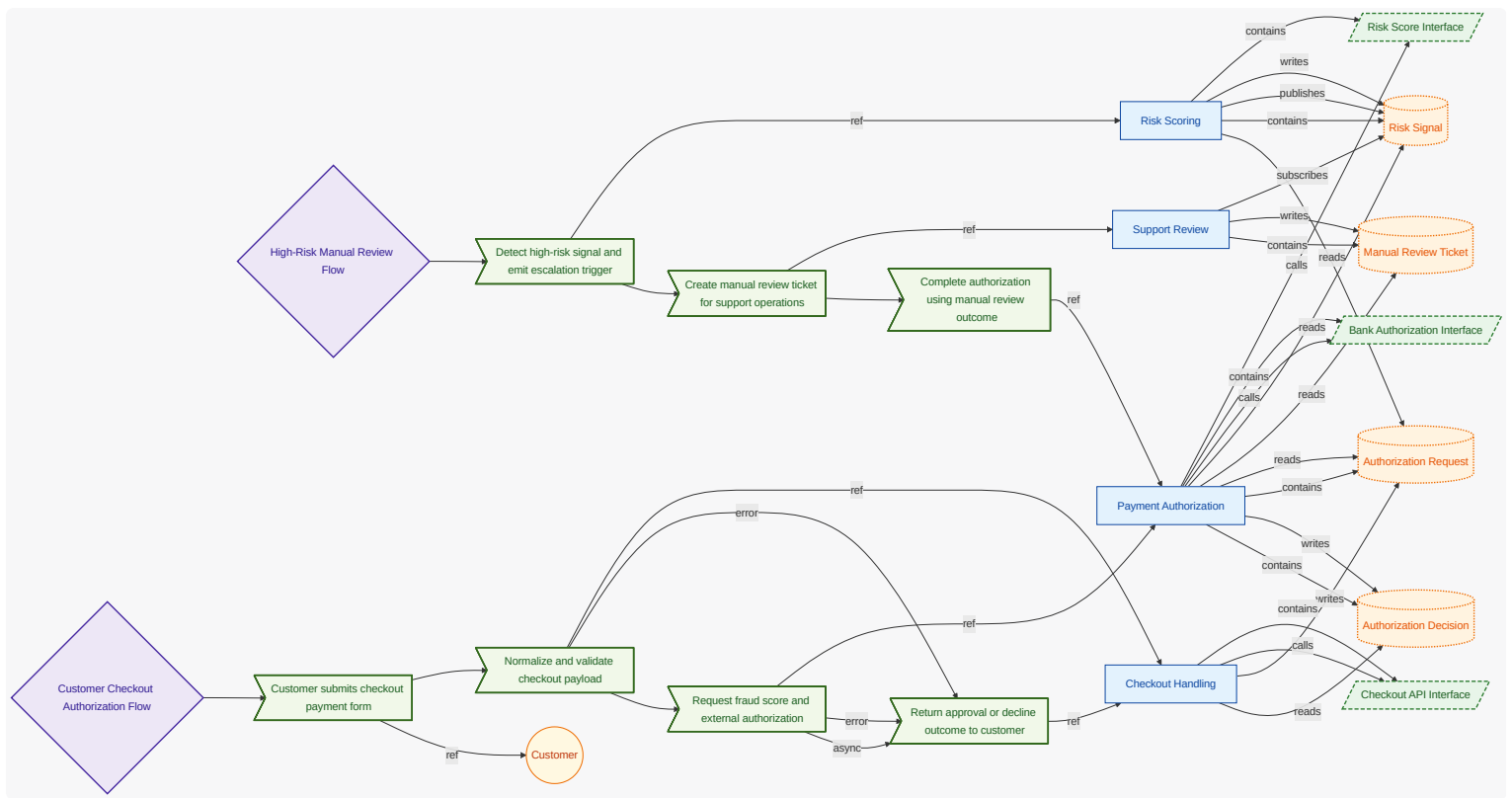
Show user-intent-to-outcome causal flow , including ordered steps, data movement, and error/async branches.

12.1. What This View Answers

- What happens from user intent to system outcome, step by step?
- What data enters/exits each step and where are decisions made?
- Where are async and error paths and what completes each path?

12.2. Interaction Flow Diagram

What this diagram shows: authored interaction flow steps, step ordering, async markers, and referenced actors/interfaces/units for this view.



12.3. Coverage Gaps

Coverage summary: 4/4 units have direct evidence coverage in this view .

- No major coverage gaps detected from current authored and inferred inputs.

12.4. Recommended Next Evidence Additions

- No immediate evidence additions are required for this view .

12.5. Functional Groups and Units (View Scoped)

12.6. Requirement-to-Unit Mapping (Compact)

What this matrix shows: authored requirement-to-unit mappings in a compact square layout (requirements as rows, functional units as columns).

Requirement	FU-CHECKOUT	FU-PAYMENT-AUTHORIZATION	FU-RISK-SCORING	FU-SUPPORT-REVIEW
REQ-PAY-001	X	X		
REQ-PAY-002			X	
REQ-PAY-003	X			
REQ-PAY-004		X		X
REQ-PAY-005			X	
REQ-PAY-006	X	X		
REQ-PAY-007	X	X		
REQ-PAY-008	X			
REQ-PAY-009		X		X

12.7. Verification Result Mapping

What this section shows: per-requirement result mapping inferred from test-result artifacts.

Check ID	Requirement	Result	Evidence / Notes
VER-INF-E2E-AUTHORIZED_CHECKOUT_FLOW-8C6597	REQ-PAY-001	not-run	none; No parsed test-result artifact for this requirement yet.
VER-INF-INTEGRATION-FRAUD_GATE_TEST-12F3BD	REQ-PAY-002	pass	test-results/integration-fraud-gate.json
VER-INF-TEST-CHECKOUT_DECLINE_RESPONSE_TEST-365ACE	REQ-PAY-003	pass	test-results/contract-checkout-decline.json
VER-INF-UNIT-CHECKOUT_DECLINE_REASON_TEST-5F4C93	REQ-PAY-003	not-run	none; No parsed test-result artifact for this requirement yet.

Check ID	Requirement	Result	Evidence / Notes
VER-INF-INTEGRATION-FRAUD_GATE_TEST-12F3BD	REQ-PAY-004	pass	test-results/integration-fraud-gate.json
VER-INF-INTEGRATION-AUDIT_RECORD_PERSISTENCE_TEST-B333A2	REQ-PAY-005	not-run	none; No parsed test-result artifact for this requirement yet.
VER-INF-TEST-CHECKOUT_DECLINE_RESPONSE_TEST-365ACE	REQ-PAY-006	pass	test-results/contract-checkout-decline.json
VER-INF-UNIT-CHECKOUT_DECLINE_REASON_TEST-5F4C93	REQ-PAY-008	not-run	none; No parsed test-result artifact for this requirement yet.

13. Traceability Appendix

13.1. Requirement Details

13.1.1. REQ-PAY-001

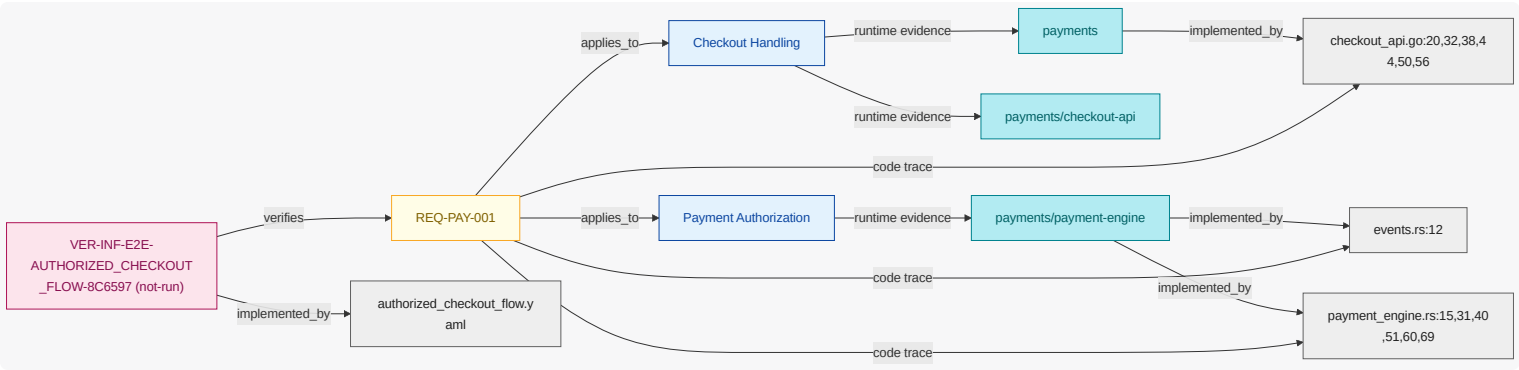
While normal mode is active , when payment authorization is requested , the payments system shall create a payment session.

NOTE

Core authorization path from checkout to bank gateway.

Requirement-to-Unit-to-Evidence Coverage

What this diagram shows: this requirement-to-unit mapping extended with inferred runtime/code plus verification evidence attached to each requirement and unit.



13.1.2. REQ-PAY-002

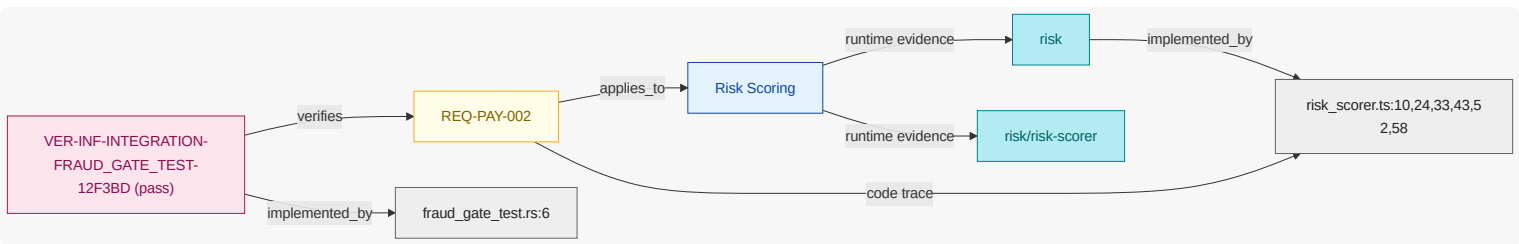
Where fraud check is enabled , when payment authorization is requested , the fraud detection system shall calculate a risk score before approval.

NOTE

Fraud scoring gate before approval.

Requirement-to-Unit-to-Evidence Coverage

What this diagram shows: this requirement-to-unit mapping extended with inferred runtime/code plus verification evidence attached to each requirement and unit.



13.1.3. REQ-PAY-003

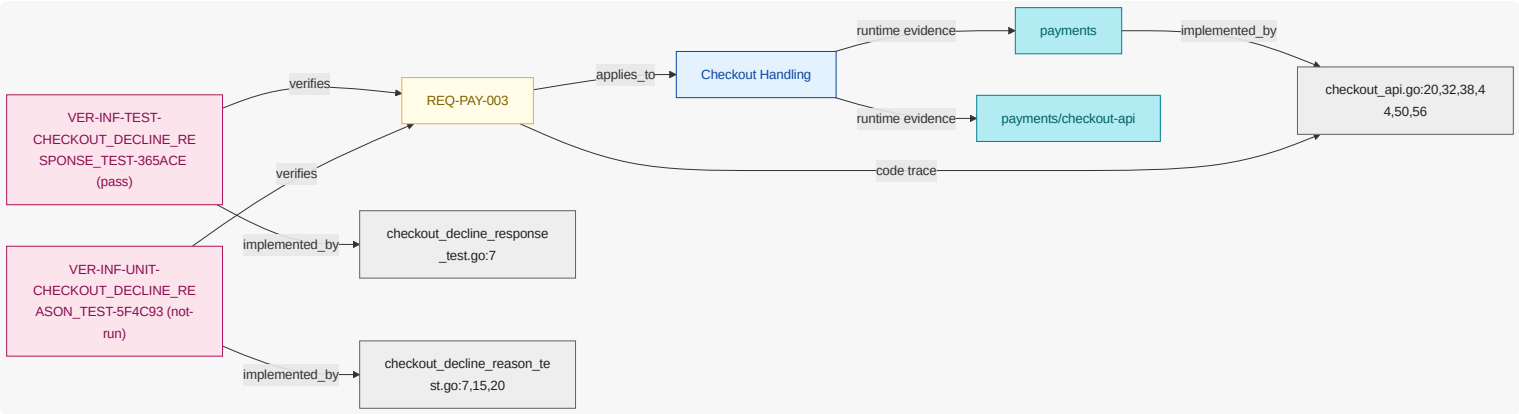
If payment is declined , then the payments system shall present a decline reason to customer .

NOTE

Decline handling and customer feedback.

Requirement-to-Unit-to-Evidence Coverage

What this diagram shows: this requirement-to-unit mapping extended with inferred runtime/code plus verification evidence attached to each requirement and unit.



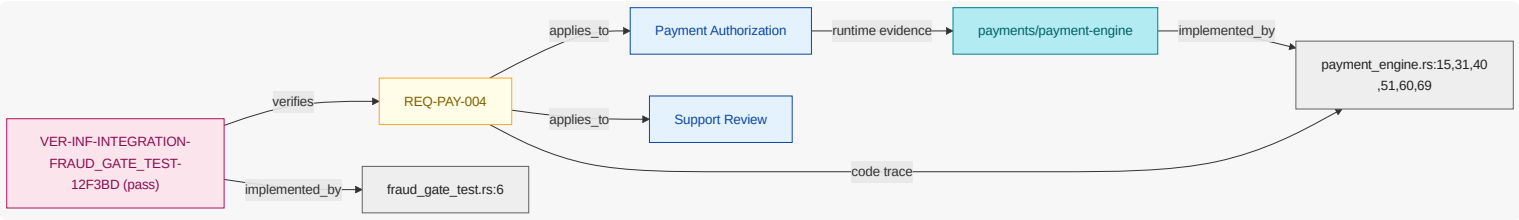
13.1.4. REQ-PAY-004

While checkout is active, when payment authorization is requested and risk score is high and risk threshold is exceeded, the payments system shall place the payment in payment review is pending.

NOTE Escalation flow for high-risk payments.

Requirement-to-Unit-to-Evidence Coverage

What this diagram shows: this requirement-to-unit mapping extended with inferred runtime/code plus verification evidence attached to each requirement and unit.



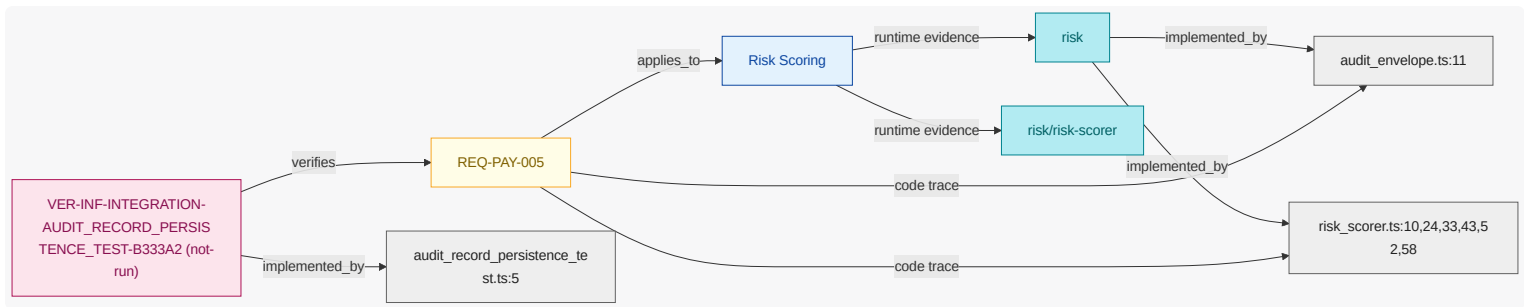
13.1.5. REQ-PAY-005

Where fraud check is enabled, when payment authorization is requested, the payments system shall persist an audit record with payment id plus risk score.

NOTE Auditability for authorization decisions.

Requirement-to-Unit-to-Evidence Coverage

What this diagram shows: this requirement-to-unit mapping extended with inferred runtime/code plus verification evidence attached to each requirement and unit.



13.1.6. REQ-PAY-006

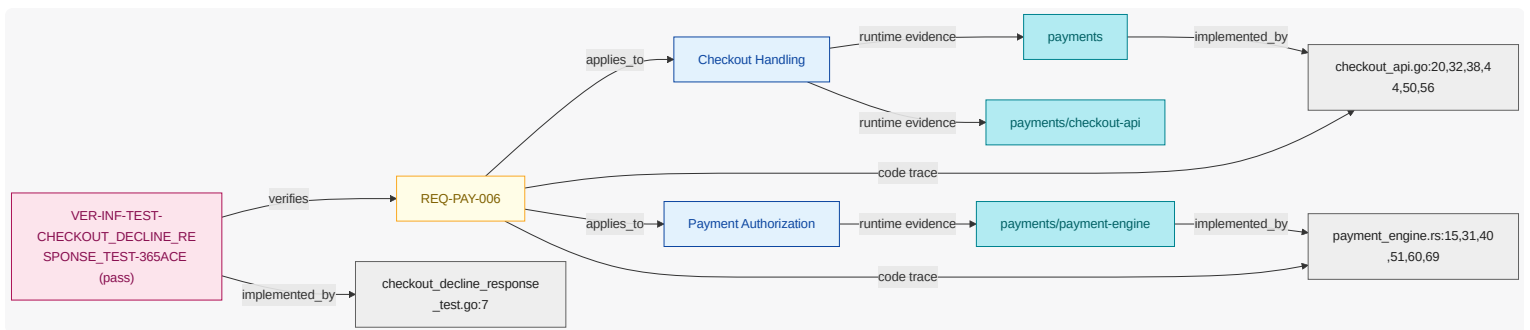
If bank link is unavailable , then the payments system shall present a temporary unavailable message to customer until bank link is available .

NOTE

Fallback behavior when external banking path is down.

Requirement-to-Unit-to-Evidence Coverage

What this diagram shows: this requirement-to-unit mapping extended with inferred runtime/code plus verification evidence attached to each requirement and unit.



13.1.7. REQ-PAY-007

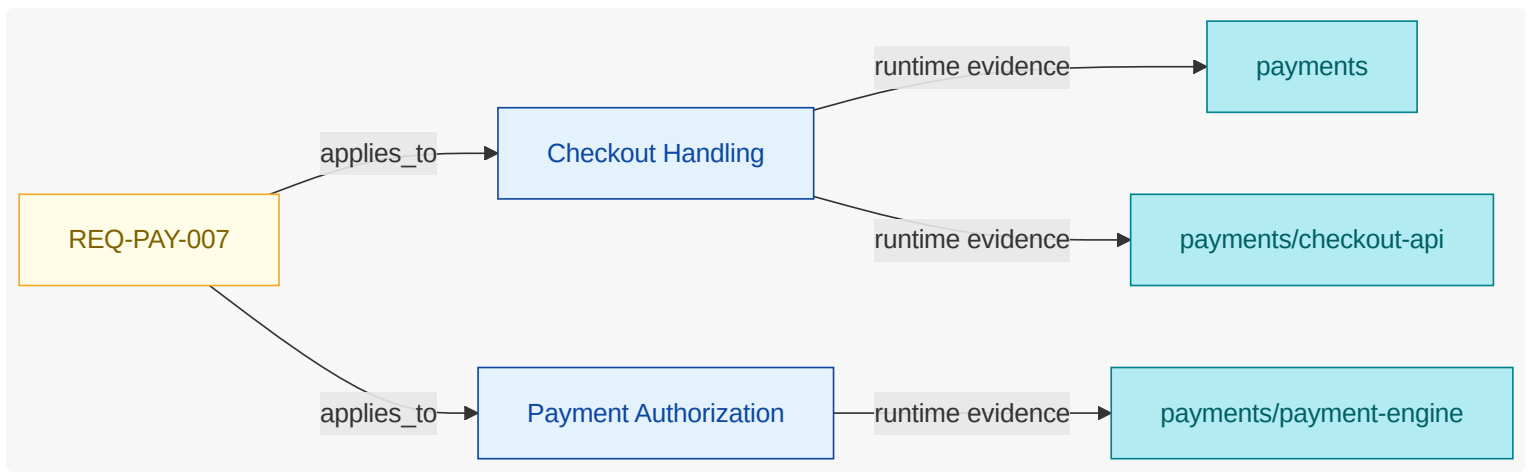
While checkout is active , when payment authorization is requested and 3DS verification is required , the payments system shall request authorization from bank gateway endpoint .

NOTE

External authorization call contract.

Requirement-to-Unit-to-Evidence Coverage

What this diagram shows: this requirement-to-unit mapping extended with inferred runtime/code plus verification evidence attached to each requirement and unit.



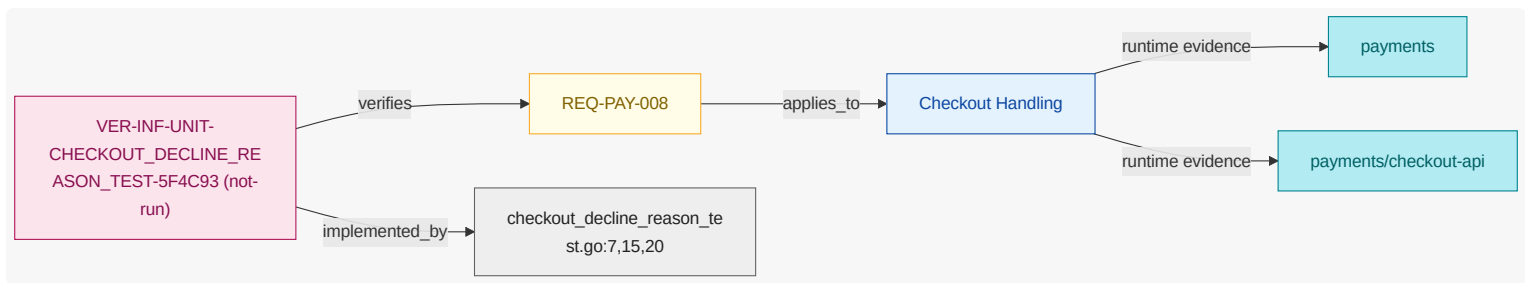
13.1.8. REQ-PAY-008

If payment is declined , then the payments system shall present a retry option to customer .

NOTE | Customer retry path requirement after decline .

Requirement-to-Unit-to-Evidence Coverage

What this diagram shows: this requirement-to-unit mapping extended with inferred runtime/code plus verification evidence attached to each requirement and unit.



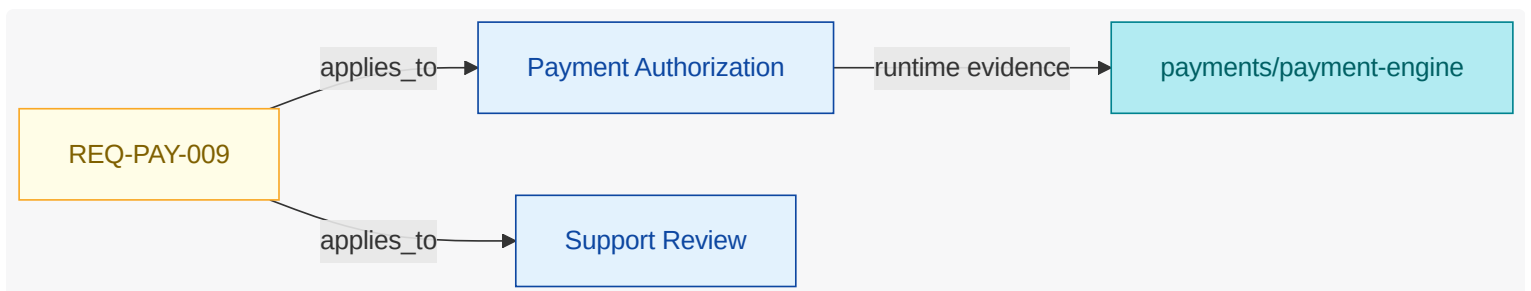
13.1.9. REQ-PAY-009

While checkout is active , when payment authorization is requested and risk threshold is exceeded , the payments system shall notify platform operator when support agent is notified .

NOTE | Support notification requirement for high-risk review.

Requirement-to-Unit-to-Evidence Coverage

What this diagram shows: this requirement-to-unit mapping extended with inferred runtime/code plus verification evidence attached to each requirement and unit.



13.2. Verification Inventory

What this section shows: verification checks inferred from test artifacts, linked to test code elements and mapped to verified requirements.

13.2.1. Authorized Checkout Flow

Field	Value
ID	VER-INF-E2E-AUTHORIZED_CHECKOUT_FLOW-8C6597
Kind	e2e
Status	not-run
Verifies Requirements	REQ-PAY-001
Test Code Elements	tests/e2e/authorized_checkout_flow.yaml
Derived Functional Owners	FU-CHECKOUT , FU-PAYMENT-AUTHORIZATION
Result Summary	not-run:1
Evidence	tests/e2e/authorized_checkout_flow.yaml
Notes	executes authorized checkout flow from session start through payment authorization success

13.2.2. Audit Record Persistence Test

Field	Value
ID	VER-INF-INTEGRATION-AUDIT_RECORD_PERSISTENCE_TEST-B333A2
Kind	integration
Status	not-run
Verifies Requirements	REQ-PAY-005
Test Code Elements	audit_record_persistence_test.ts:5
Derived Functional Owners	FU-RISK-SCORING
Result Summary	not-run:1
Evidence	tests/integration/audit_record_persistence_test.ts
Notes	checks audit record persistence includes payment id and computed risk score

13.2.3. Fraud Gate Test

Field	Value
ID	VER-INF-INTEGRATION-FRAUD_GATE_TEST-12F3BD
Kind	integration
Status	pass
Verifies Requirements	REQ-PAY-002 , REQ-PAY-004
Test Code Elements	fraud_gate_test.rs:6
Derived Functional Owners	FU-PAYMENT-AUTHORIZATION , FU-RISK-SCORING , FU-SUPPORT-REVIEW
Result Summary	pass:2
Evidence	test-results/integration-fraud-gate.json, tests/integration/fraud_gate_test.rs
Notes	validates fraud gate escalation and block decisions before authorization completion

13.2.4. Checkout Decline Response Test

Field	Value
ID	VER-INF-TEST-CHECKOUT_DECLINE_RESPONSE_TEST-365ACE
Kind	test
Status	pass
Verifies Requirements	REQ-PAY-003 , REQ-PAY-006
Test Code Elements	checkout_decline_response_test.go:7
Derived Functional Owners	FU-CHECKOUT , FU-PAYMENT-AUTHORIZATION
Result Summary	pass:2
Evidence	test-results/contract-checkout-decline.json, tests/contract/checkout_decline_response_test.go
Notes	validates checkout decline response contract includes reason and retry guidance

13.2.5. Checkout Decline Reason Test

Field	Value
ID	VER-INF-UNIT-CHECKOUT_DECLINE_REASON_TEST-5F4C93
Kind	unit

Field	Value
Status	not-run
Verifies Requirements	REQ-PAY-003 , REQ-PAY-008
Test Code Elements	checkout_decline_reason_test.go:7,15,20
Derived Functional Owners	FU-CHECKOUT
Result Summary	not-run:2
Evidence	tests/unit/checkout_decline_reason_test.go
Notes	validates checkout decline reason normalization and retry policy messaging

14. Reference Index

14.1. Authored References

CTRL-PAYMENTS-CALLBACK-NONCE

category=protocol-integrity; description=Enforce nonce freshness and idempotency on bank callback processing.

Key	Value
Kind	Control
Name	Callback Nonce and Idempotency Guard
Mentioned In	Security View

CTRL-PAYMENTS-IMAGE-DIGEST

category=supply-chain; description=Enforce immutable digest-pinned container image references.

Key	Value
Kind	Control
Name	Immutable Image Digests
Mentioned In	n/a

CTRL-PAYMENTS-SSO-MFA

category=identity-access; description=Enforce MFA and conditional access for privileged operations.

Key	Value
Kind	Control
Name	SSO MFA Enforcement
Mentioned In	Security View

DO-PAYMENTS-AUTH-DECISION

termRef=DATA-AUTH-DECISION; schemaRef=schemas/auth-decision.json; sensitivity=internal

Key	Value
Kind	Data Object
Name	Authorization Decision

Key	Value
Mentioned In	Security View , REQ-PAY-005

DO-PAYMENTS-AUTH-REQUEST

termRef=DATA-PAYMENT-REQUEST; schemaRef=schemas/auth-request.json; sensitivity=confidential

Key	Value
Kind	Data Object
Name	Authorization Request
Mentioned In	Security View

DO-PAYMENTS-REVIEW-TICKET

termRef=n/a; schemaRef=schemas/review-ticket.json; sensitivity=confidential

Key	Value
Kind	Data Object
Name	Manual Review Ticket
Mentioned In	Security View

DO-PAYMENTS-RISK-SIGNAL

termRef=n/a; schemaRef=schemas/risk-signal.json; sensitivity=internal

Key	Value
Kind	Data Object
Name	Risk Signal
Mentioned In	Security View

DEP-PAYMENTS-BANK-EDGE

environment=prod; region=us-east-1; account=external; cluster=bank-edge; namespace=partner; trustZone=external

Key	Value
Kind	Deployment Target
Name	Bank Edge Integration Zone
Mentioned In	n/a

DEP-PAYMENTS-CLUSTER-PROD

environment=prod; region=us-east-1; account=shared-platform; cluster=payments-prod; namespace=payments; trustZone=app

Key	Value
Kind	Deployment Target
Name	Payments Cluster Production
Mentioned In	n/a

EVT-PAYMENTS-AUTH-COMPLETED

Authorization decision returned to checkout.

Key	Value
Kind	Event
Name	Authorization Completed
Mentioned In	n/a

EVT-PAYMENTS-AUTH-REQUESTED

Request sent to authorization orchestration.

Key	Value
Kind	Event
Name	Authorization Requested
Mentioned In	n/a

FLOW-CUSTOMER-CHECKOUT

entry=submit-payment; exits=show-outcome; steps=4

Key	Value
Kind	Flow
Name	Customer Checkout Authorization Flow
Mentioned In	Security View

FLOW-PAYMENTS-MANUAL-REVIEW

entry=detect-high-risk; exits=complete-review; steps=3

Key	Value
Kind	Flow
Name	High-Risk Manual Review Flow
Mentioned In	Security View

FLOW-CUSTOMER-CHECKOUT::authorize-payment

kind=system_action; ref=FU-PAYMENT-AUTHORIZATION; action=Request fraud score and external authorization; dataIn=normalized_payment_request; dataOut=authorization_decision; async=true

Key	Value
Kind	Flow Step
Name	Request fraud score and external authorization
Mentioned In	n/a

FLOW-CUSTOMER-CHECKOUT::normalize-request

kind=system_action; ref=FU-CHECKOUT; action=Normalize and validate checkout payload; dataIn=; dataOut=normalized_payment_request; async=false

Key	Value
Kind	Flow Step
Name	Normalize and validate checkout payload
Mentioned In	n/a

FLOW-CUSTOMER-CHECKOUT::show-outcome

kind=system_action; ref=FU-CHECKOUT; action=Return approval or decline outcome to customer; dataIn=authorization_decision; dataOut=; async=false

Key	Value
Kind	Flow Step
Name	Return approval or decline outcome to customer
Mentioned In	n/a

FLOW-CUSTOMER-CHECKOUT::submit-payment

kind=user_action; ref=ACT-CUSTOMER; action=Customer submits checkout payment form; dataIn=payment_method, billing_address, amount; dataOut=; async=false

Key	Value
Kind	Flow Step
Name	Customer submits checkout payment form
Mentioned In	n/a

FLOW-PAYMENTS-MANUAL-REVIEW::complete-review

kind=system_action; ref=FU-PAYMENT-AUTHORIZATION; action=Complete authorization using manual review outcome; dataIn=review_ticket; dataOut=; async=false

Key	Value
Kind	Flow Step
Name	Complete authorization using manual review outcome
Mentioned In	n/a

FLOW-PAYMENTS-MANUAL-REVIEW::create-review-ticket

kind=system_action; ref=FU-SUPPORT-REVIEW; action=Create manual review ticket for support operations; dataIn=risk_signal; dataOut=review_ticket; async=false

Key	Value
Kind	Flow Step
Name	Create manual review ticket for support operations
Mentioned In	n/a

FLOW-PAYMENTS-MANUAL-REVIEW::detect-high-risk

kind=system_action; ref=FU-RISK-SCORING; action=Detect high-risk signal and emit escalation trigger; dataIn=; dataOut=risk_signal; async=false

Key	Value
Kind	Flow Step
Name	Detect high-risk signal and emit escalation trigger
Mentioned In	n/a

IF-PAYMENTS-BANK-AUTH

protocol=https; endpoint=/bank/authorize; schemaRef=schemas/bank-auth.json; owner=FU-PAYMENT-AUTHORIZATION

Key	Value
Kind	Interface
Name	Bank Authorization Interface
Mentioned In	Security View

IF-PAYMENTS-CHECKOUT-API

protocol=https; endpoint=/api/checkout; schemaRef=schemas/checkout-request.json; owner=FU-CHECKOUT

Key	Value
Kind	Interface
Name	Checkout API Interface
Mentioned In	Security View

IF-PAYMENTS-RISK-SCORE-API

protocol=https; endpoint=/risk/score; schemaRef=schemas/risk-score.json; owner=FU-RISK-SCORING

Key	Value
Kind	Interface
Name	Risk Score Interface
Mentioned In	n/a

REQ-PAY-001

While normal mode is active, when payment authorization is requested, the payments system shall create a payment session.

Key	Value
Kind	Requirement
Name	REQ-PAY-001
Mentioned In	Architecture Intent View , Deployment View , Interaction Flow View , Authorized Checkout Flow

REQ-PAY-002

Where fraud check is enabled, when payment authorization is requested, the fraud detection system shall calculate a risk score before approval.

Key	Value
Kind	Requirement
Name	REQ-PAY-002
Mentioned In	Architecture Intent View , Deployment View , Interaction Flow View , Fraud Gate Test

REQ-PAY-003

If payment is declined, then the payments system shall present a decline reason to customer.

Key	Value
Kind	Requirement
Name	REQ-PAY-003
Mentioned In	Architecture Intent View , Deployment View , Interaction Flow View , Checkout Decline Response Test , Checkout Decline Reason Test

REQ-PAY-004

While checkout is active, when payment authorization is requested and risk score is high and risk threshold is exceeded, the payments system shall place the payment in payment review is pending.

Key	Value
Kind	Requirement
Name	REQ-PAY-004
Mentioned In	Architecture Intent View , Deployment View , Interaction Flow View , Fraud Gate Test

REQ-PAY-005

Where fraud check is enabled, when payment authorization is requested, the payments system shall persist an audit record with payment id plus risk score.

Key	Value
Kind	Requirement
Name	REQ-PAY-005
Mentioned In	Architecture Intent View , Deployment View , Interaction Flow View , Audit Record Persistence Test

REQ-PAY-006

If bank link is unavailable, then the payments system shall present a temporary unavailable message to customer until bank link is available.

Key	Value
Kind	Requirement
Name	REQ-PAY-006
Mentioned In	Architecture Intent View , Deployment View , Interaction Flow View , Checkout Decline Response Test

REQ-PAY-007

While checkout is active, when payment authorization is requested and 3DS verification is required, the payments system shall request authorization from bank gateway endpoint.

Key	Value
Kind	Requirement
Name	REQ-PAY-007
Mentioned In	Architecture Intent View , Deployment View

REQ-PAY-008

If payment is declined, then the payments system shall present a retry option to customer.

Key	Value
Kind	Requirement
Name	REQ-PAY-008
Mentioned In	Architecture Intent View , Deployment View , Interaction Flow View , Checkout Decline Reason Test

REQ-PAY-009

While checkout is active, when payment authorization is requested and risk threshold is exceeded, the payments system shall notify platform operator when support agent is notified.

Key	Value
Kind	Requirement
Name	REQ-PAY-009
Mentioned In	Architecture Intent View , Deployment View

STATE-PAYMENTS-AUTHORIZED

Authorization decision approved.

Key	Value
Kind	State
Name	Payment Authorized
Mentioned In	n/a

STATE-PAYMENTS-CHECKOUT-RECEIVED

Payment request accepted at checkout boundary.

Key	Value
Kind	State
Name	Checkout Received
Mentioned In	n/a

TB-PAYMENTS-EXTERNAL-BANK

Separates internal payment authorization from external bank services.

Key	Value
Kind	Trust Boundary
Name	External Bank Boundary
Mentioned In	Security View

TB-PAYMENTS-PLATFORM-CONTROL

Separates app workloads from platform control-plane authority.

Key	Value
Kind	Trust Boundary
Name	Platform Control Boundary
Mentioned In	n/a

14.2. Catalog References

ACT-CUSTOMER

End user submitting payment details during checkout.

Key	Value
Kind	Catalog Actor
Name	customer
Mentioned In	Architecture Intent View , Security View , REQ-PAY-003 , REQ-PAY-006 , REQ-PAY-008

ACT-PLATFORM-OPERATOR

Role responsible for GitOps and platform lifecycle operations.

Key	Value
Kind	Catalog Actor
Name	platform operator
Mentioned In	Security View , REQ-PAY-009

ACT-SUPPORT

Operations role that investigates declines and high-risk review cases.

Key	Value
Kind	Catalog Actor
Name	support agent
Mentioned In	Architecture Intent View , Deployment View , Security View , REQ-PAY-009

3DS required

Condition indicating strong customer authentication must be performed.

Key	Value
Kind	Catalog Alias
Name	3DS required
Mentioned In	n/a

auth

Coordinates authorization flow and bank gateway interaction.

Key	Value
Kind	Catalog Alias
Name	auth
Mentioned In	n/a

authorization requested

Event raised when checkout asks payment engine to authorize a transaction.

Key	Value
Kind	Catalog Alias
Name	authorization requested
Mentioned In	n/a

bank API

External banking endpoint used for card authorization and decline decisions.

Key	Value
Kind	Catalog Alias
Name	bank API
Mentioned In	n/a

bank link down

Event raised when payment engine cannot reach the external bank gateway.

Key	Value
Kind	Catalog Alias
Name	bank link down
Mentioned In	n/a

bank link up

Connectivity state showing bank gateway communication is currently healthy.

Key	Value
Kind	Catalog Alias

Key	Value
Name	bank link up
Mentioned In	n/a

buyer

End user submitting payment details during checkout.

Key	Value
Kind	Catalog Alias
Name	buyer
Mentioned In	n/a

callback replay

Replay of a valid callback to induce duplicate or unauthorized state transitions.

Key	Value
Kind	Catalog Alias
Name	callback replay
Mentioned In	n/a

checkout

Handles checkout session start and customer-facing payment messaging.

Key	Value
Kind	Catalog Alias
Name	checkout
Mentioned In	Architecture Intent View , Deployment View , Security View , REQ-PAY-001 , Checkout Decline Response Test , Checkout Decline Reason Test

checkout active

Processing state where the user is actively submitting or confirming payment.

Key	Value
Kind	Catalog Alias

Key	Value
Name	checkout active
Mentioned In	n/a

day1 provisioning

Provides cluster-level platform setup and environment bootstrap.

Key	Value
Kind	Catalog Alias
Name	day1 provisioning
Mentioned In	n/a

day2 operations

Operates declarative delivery and release management flows.

Key	Value
Kind	Catalog Alias
Name	day2 operations
Mentioned In	n/a

decline

Event indicating authorization was rejected and customer decline handling must execute.

Key	Value
Kind	Catalog Alias
Name	decline
Mentioned In	Security View , REQ-PAY-003 , REQ-PAY-008 , Checkout Decline Response Test

decline code

Structured reason code or message explaining why authorization failed.

Key	Value
Kind	Catalog Alias
Name	decline code

Key	Value
Mentioned In	n/a

decline reasons

Structured reason code or message explaining why authorization failed.

Key	Value
Kind	Catalog Alias
Name	decline reasons
Mentioned In	n/a

dependency compromise

Supply-chain compromise in runtime image or code dependency.

Key	Value
Kind	Catalog Alias
Name	dependency compromise
Mentioned In	n/a

fraud abuse

Coordinated abuse pattern using synthetic identities, stolen instruments, or velocity anomalies to obtain unauthorized approvals.

Key	Value
Kind	Catalog Alias
Name	fraud abuse
Mentioned In	n/a

fraud check

Feature flag controlling whether risk scoring is required before authorization.

Key	Value
Kind	Catalog Alias
Name	fraud check

Key	Value
Mentioned In	n/a

fraud domain

Functional group for risk scoring and fraud review capabilities.

Key	Value
Kind	Catalog Alias
Name	fraud domain
Mentioned In	n/a

fraud scoring

Evaluates transaction risk and returns score classification.

Key	Value
Kind	Catalog Alias
Name	fraud scoring
Mentioned In	Architecture Intent View , REQ-PAY-002

helm

Runtime packaging and deployment substrate for workloads.

Key	Value
Kind	Catalog Alias
Name	helm
Mentioned In	Architecture Intent View , Communication View , Deployment View

high risk

Event emitted when computed fraud risk exceeds the configured high-risk threshold.

Key	Value
Kind	Catalog Alias
Name	high risk
Mentioned In	n/a

high-risk classification

Event emitted when computed fraud risk exceeds the configured high-risk threshold.

Key	Value
Kind	Catalog Alias
Name	high-risk classification
Mentioned In	n/a

high-risk classifications

Event emitted when computed fraud risk exceeds the configured high-risk threshold.

Key	Value
Kind	Catalog Alias
Name	high-risk classifications
Mentioned In	n/a

malicious request

Crafted payload attempting to bypass validation or authorization logic.

Key	Value
Kind	Catalog Alias
Name	malicious request
Mentioned In	n/a

manual review

Supports manual review and escalation handling for risky transactions.

Key	Value
Kind	Catalog Alias
Name	manual review
Mentioned In	n/a

normal mode

Standard operating mode with full external dependency usage enabled.

Key	Value
Kind	Catalog Alias
Name	normal mode
Mentioned In	n/a

payment auth requested

Event raised when checkout asks payment engine to authorize a transaction.

Key	Value
Kind	Catalog Alias
Name	payment auth requested
Mentioned In	n/a

payment declined

Event indicating authorization was rejected and customer decline handling must execute.

Key	Value
Kind	Catalog Alias
Name	payment declined
Mentioned In	n/a

payment fraud

Coordinated abuse pattern using synthetic identities, stolen instruments, or velocity anomalies to obtain unauthorized approvals.

Key	Value
Kind	Catalog Alias
Name	payment fraud
Mentioned In	n/a

payments domain

Functional group for checkout and authorization capabilities.

Key	Value
Kind	Catalog Alias
Name	payments domain
Mentioned In	n/a

platform engineering

Functional group for provisioning and platform operations capabilities.

Key	Value
Kind	Catalog Alias
Name	platform engineering
Mentioned In	n/a

platform ops

Role responsible for GitOps and platform lifecycle operations.

Key	Value
Kind	Catalog Alias
Name	platform ops
Mentioned In	n/a

postgres driver

Third-party library used for application data persistence connectivity.

Key	Value
Kind	Catalog Alias
Name	postgres driver
Mentioned In	n/a

review pending

Transaction state requiring manual support review before final disposition.

Key	Value
Kind	Catalog Alias

Key	Value
Name	review pending
Mentioned In	n/a

review state

Transaction state requiring manual support review before final disposition.

Key	Value
Kind	Catalog Alias
Name	review state
Mentioned In	n/a

risk above threshold

Condition indicating risk score crossed a policy threshold for escalation.

Key	Value
Kind	Catalog Alias
Name	risk above threshold
Mentioned In	n/a

standard operating mode

Standard operating mode with full external dependency usage enabled.

Key	Value
Kind	Catalog Alias
Name	standard operating mode
Mentioned In	n/a

support

Operations role that investigates declines and high-risk review cases.

Key	Value
Kind	Catalog Alias
Name	support

Key	Value
Mentioned In	n/a

support notified

Event indicating manual review notification was sent to support operations.

Key	Value
Kind	Catalog Alias
Name	support notified
Mentioned In	n/a

the fraud detection system

Fraud scoring and review subsystem participating in payment decisions.

Key	Value
Kind	Catalog Alias
Name	the fraud detection system
Mentioned In	REQ-PAY-002

the payments system

Payment processing system-of-interest covered by this architecture.

Key	Value
Kind	Catalog Alias
Name	the payments system
Mentioned In	REQ-PAY-001 , REQ-PAY-003 , REQ-PAY-004 , REQ-PAY-005 , REQ-PAY-006 , REQ-PAY-007 , REQ-PAY-008 , REQ-PAY-009

AV-COMPROMISED-DEPENDENCY

Supply-chain compromise in runtime image or code dependency.

Key	Value
Kind	Catalog Attack Vector
Name	compromised dependency

Key	Value
Mentioned In	n/a

AV-FRAUDULENT-TRANSACTION-PATTERN

Coordinated abuse pattern using synthetic identities, stolen instruments, or velocity anomalies to obtain unauthorized approvals.

Key	Value
Kind	Catalog Attack Vector
Name	fraudulent transaction pattern
Mentioned In	Security View

AV-MALICIOUS-API-REQUEST

Crafted payload attempting to bypass validation or authorization logic.

Key	Value
Kind	Catalog Attack Vector
Name	malicious api request
Mentioned In	Security View

AV-REPLAYED-AUTH-CALLBACK

Replay of a valid callback to induce duplicate or unauthorized state transitions.

Key	Value
Kind	Catalog Attack Vector
Name	replayed authorization callback
Mentioned In	Security View

COND-3DS-REQUIRED

Condition indicating strong customer authentication must be performed.

Key	Value
Kind	Catalog Condition
Name	3DS verification is required

Key	Value
Mentioned In	REQ-PAY-007

COND-RISK-THRESHOLD-EXCEEDED

Condition indicating risk score crossed a policy threshold for escalation.

Key	Value
Kind	Catalog Condition
Name	risk threshold is exceeded
Mentioned In	REQ-PAY-004 , REQ-PAY-009

DATA-DECLINE-REASON

Structured reason code or message explaining why authorization failed.

Key	Value
Kind	Catalog Data Term
Name	decline reason
Mentioned In	REQ-PAY-003 , Checkout Decline Reason Test

DATA-PAYMENT-ID

Stable identifier used to correlate a payment across services and records.

Key	Value
Kind	Catalog Data Term
Name	payment id
Mentioned In	REQ-PAY-005 , Audit Record Persistence Test

DATA-RISK-SCORE

Numeric fraud score produced by risk evaluation logic.

Key	Value
Kind	Catalog Data Term
Name	risk score
Mentioned In	REQ-PAY-002 , REQ-PAY-005 , Audit Record Persistence Test

EVT-BANK-LINK-UNAVAILABLE

Event raised when payment engine cannot reach the external bank gateway.

Key	Value
Kind	Catalog Event
Name	bank link is unavailable
Mentioned In	REQ-PAY-006

EVT-PAYMENT-AUTH-REQUESTED

Event raised when checkout asks payment engine to authorize a transaction.

Key	Value
Kind	Catalog Event
Name	payment authorization is requested
Mentioned In	REQ-PAY-001 , REQ-PAY-002 , REQ-PAY-004 , REQ-PAY-005 , REQ-PAY-007 , REQ-PAY-009

EVT-PAYMENT-DECLINED

Event indicating authorization was rejected and customer decline handling must execute.

Key	Value
Kind	Catalog Event
Name	payment is declined
Mentioned In	REQ-PAY-003 , REQ-PAY-008

EVT-RISK-HIGH

Event emitted when computed fraud risk exceeds the configured high-risk threshold.

Key	Value
Kind	Catalog Event
Name	risk score is high
Mentioned In	REQ-PAY-004

EVT-SUPPORT-NOTIFIED

Event indicating manual review notification was sent to support operations.

Key	Value
Kind	Catalog Event
Name	support agent is notified
Mentioned In	REQ-PAY-009

FEAT-FRAUD-CHECK

Feature flag controlling whether risk scoring is required before authorization.

Key	Value
Kind	Catalog Feature
Name	fraud check is enabled
Mentioned In	REQ-PAY-002 , REQ-PAY-005

FG-FRAUD

Functional group for risk scoring and fraud review capabilities.

Key	Value
Kind	Catalog Functional Group
Name	fraud evaluation
Mentioned In	Architecture Intent View , Deployment View

FG-PAYMENTS

Functional group for checkout and authorization capabilities.

Key	Value
Kind	Catalog Functional Group
Name	payments
Mentioned In	Architecture Intent View , Deployment View , Security View , REQ-PAY-004

FG-PLATFORM

Functional group for provisioning and platform operations capabilities.

Key	Value
Kind	Catalog Functional Group

Key	Value
Name	platform
Mentioned In	Architecture Intent View , Deployment View

FU-CHECKOUT

Handles checkout session start and customer-facing payment messaging.

Key	Value
Kind	Catalog Functional Unit
Name	checkout handling
Mentioned In	Architecture Intent View , Deployment View , Security View , Authorized Checkout Flow , Checkout Decline Response Test , Checkout Decline Reason Test

FU-CLUSTER-PROVISIONING

Provides cluster-level platform setup and environment bootstrap.

Key	Value
Kind	Catalog Functional Unit
Name	cluster provisioning
Mentioned In	Architecture Intent View , Deployment View , Traceability View

FU-GITOPS-OPERATIONS

Operates declarative delivery and release management flows.

Key	Value
Kind	Catalog Functional Unit
Name	gitops operations
Mentioned In	Architecture Intent View , Deployment View , Traceability View

FU-PAYMENT-AUTHORIZATION

Coordinates authorization flow and bank gateway interaction.

Key	Value
Kind	Catalog Functional Unit

Key	Value
Name	payment authorization
Mentioned In	Architecture Intent View , Deployment View , Security View , Authorized Checkout Flow , Fraud Gate Test , Checkout Decline Response Test

FU-RISK-SCORING

Evaluates transaction risk and returns score classification.

Key	Value
Kind	Catalog Functional Unit
Name	risk scoring
Mentioned In	Architecture Intent View , Deployment View , Security View , Audit Record Persistence Test , Fraud Gate Test

FU-SUPPORT-REVIEW

Supports manual review and escalation handling for risky transactions.

Key	Value
Kind	Catalog Functional Unit
Name	support review
Mentioned In	Architecture Intent View , Communication View , Deployment View , Security View , Traceability View , Fraud Gate Test

MODE-NORMAL

Standard operating mode with full external dependency usage enabled.

Key	Value
Kind	Catalog Mode
Name	normal mode is active
Mentioned In	REQ-PAY-001

REF-BANK-GATEWAY-ENDPOINT

External banking endpoint used for card authorization and decline decisions.

Key	Value
Kind	Catalog Referenced Element
Name	bank gateway endpoint
Mentioned In	Architecture Intent View , Deployment View , Security View , REQ-PAY-007

REF-HELM-PLATFORM

Runtime packaging and deployment substrate for workloads.

Key	Value
Kind	Catalog Referenced Element
Name	helm platform
Mentioned In	n/a

REF-POSTGRES-DRIVER

Third-party library used for application data persistence connectivity.

Key	Value
Kind	Catalog Referenced Element
Name	postgresql client driver
Mentioned In	Architecture Intent View , Deployment View , Security View

STATE-BANK-LINK-UP

Connectivity state showing bank gateway communication is currently healthy.

Key	Value
Kind	Catalog State
Name	bank link is available
Mentioned In	REQ-PAY-006

STATE-CHECKOUT-ACTIVE

Processing state where the user is actively submitting or confirming payment.

Key	Value
Kind	Catalog State

Key	Value
Name	checkout is active
Mentioned In	REQ-PAY-004 , REQ-PAY-007 , REQ-PAY-009

STATE-REVIEW-PENDING

Transaction state requiring manual support review before final disposition.

Key	Value
Kind	Catalog State
Name	payment review is pending
Mentioned In	REQ-PAY-004

SYS-FRAUD-DETECTION-SYSTEM

Fraud scoring and review subsystem participating in payment decisions.

Key	Value
Kind	Catalog System
Name	fraud detection system
Mentioned In	n/a

SYS-PAYMENTS-SYSTEM

Payment processing system-of-interest covered by this architecture.

Key	Value
Kind	Catalog System
Name	payments system
Mentioned In	n/a

TERM-ACTOR

A person or operational role that interacts with functional units.

Key	Value
Kind	Engineering Model Term
Name	actor

Key	Value
Mentioned In	n/a

TERM-ASCIIDOC-DIAGRAM

Generated diagram block, usually Mermaid, that visualizes architecture relationships in the AsciiDoc publication.

Key	Value
Kind	Engineering Model Term
Name	AsciiDoc diagram
Mentioned In	n/a

TERM-ASCIIDOC-DOCUMENT

Human-readable generated architecture publication document assembled from authored model, inferred evidence, diagrams, references, and decisions.

Key	Value
Kind	Engineering Model Term
Name	AsciiDoc document
Mentioned In	n/a

TERM-ASCIIDOC-SECTION

Structured generated document section or row model used to render authored and inferred architecture content.

Key	Value
Kind	Engineering Model Term
Name	AsciiDoc section
Mentioned In	n/a

TERM-ATTACK-VECTOR

A technical misuse or attack path that targets functional, referenced, or runtime elements.

Key	Value
Kind	Engineering Model Term
Name	attack vector

Key	Value
Mentioned In	n/a

TERM-AUTHORED-MAPPING

An explicit relationship declared in architecture inputs between authored or referenced elements.

Key	Value
Kind	Engineering Model Term
Name	authored mapping
Mentioned In	Communication View

TERM-BUNDLE

Loaded architecture, catalog, and companion documents resolved as one working model context.

Key	Value
Kind	Engineering Model Term
Name	model bundle
Mentioned In	n/a

TERM-CATALOG

Controlled vocabulary document used to normalize model, requirement, and generated-document terminology.

Key	Value
Kind	Engineering Model Term
Name	catalog
Mentioned In	n/a

TERM-CATALOG-ENTRY

A stable catalog term with a definition and aliases for linting, linking, and generated references.

Key	Value
Kind	Engineering Model Term
Name	catalog entry
Mentioned In	n/a

TERM-CLI-COMMAND

Command-line entrypoint that coordinates loading, validation, generation, and file output for an engineering-model workflow.

Key	Value
Kind	Engineering Model Term
Name	CLI command
Mentioned In	n/a

TERM-CODE-ELEMENT

An inferred code structure or ownership element discovered from source trees and build metadata.

Key	Value
Kind	Engineering Model Term
Name	code element
Mentioned In	n/a

TERM-COMPLIANCE-MAPPING

Authored mapping that links a model control to selected compliance controls, model scope, implementation status, evidence, and responsible roles.

Key	Value
Kind	Engineering Model Term
Name	compliance mapping
Mentioned In	n/a

TERM-CONTROL

An authored security, policy, or operational control used to constrain behavior and reduce risk.

Key	Value
Kind	Engineering Model Term
Name	control
Mentioned In	Deployment View , Security View

TERM-CONTROL-VERIFICATION

Authored control verification record with method, status, threat/risk scope, findings, and evidence.

Key	Value
Kind	Engineering Model Term
Name	control verification
Mentioned In	n/a

TERM-DATA-OBJECT

An authored data artifact or contract shape traced across flow, interface, and implementation boundaries.

Key	Value
Kind	Engineering Model Term
Name	data object
Mentioned In	n/a

TERM-DECISION

Authored architecture decision record with status, context, decision text, and consequences.

Key	Value
Kind	Engineering Model Term
Name	architecture decision
Mentioned In	n/a

TERM-DEPLOYMENT-TARGET

An authored deployment destination such as environment, cluster, namespace, or registry scope.

Key	Value
Kind	Engineering Model Term
Name	deployment target
Mentioned In	n/a

TERM-DESIGN

Authored design narrative organized by model entities and architecture views.

Key	Value
Kind	Engineering Model Term

Key	Value
Name	design document
Mentioned In	n/a

TERM-DESIGN-VIEW

View-scoped design narrative attached to an authored functional group or functional unit.

Key	Value
Kind	Engineering Model Term
Name	design view
Mentioned In	n/a

TERM-EVENT

An authored trigger signal that drives transitions, flow progress, or asynchronous outcomes.

Key	Value
Kind	Engineering Model Term
Name	event
Mentioned In	Communication View , State Lifecycle View

TERM-EVIDENCE

A file, artifact, or observation used to support control, risk, threat, or verification claims.

Key	Value
Kind	Engineering Model Term
Name	evidence
Mentioned In	Communication View , Deployment View , Security View , Traceability View , State Lifecycle View , Interaction Flow View

TERM-FLOW

An authored causal interaction sequence from user/system intent to outcome, represented as ordered steps.

Key	Value
Kind	Engineering Model Term

Key	Value
Name	flow
Mentioned In	Architecture Intent View , Communication View , Security View , Interaction Flow View , REQ-PAY-004

TERM-FLOW-STEP

A single authored step in a flow that captures action, data in/out, references, and normal/error/async transitions.

Key	Value
Kind	Engineering Model Term
Name	flow step
Mentioned In	n/a

TERM-FUNCTIONAL-GROUP

A major authored capability area that groups related functional units.

Key	Value
Kind	Engineering Model Term
Name	functional group
Mentioned In	n/a

TERM-FUNCTIONAL-UNIT

An authored working unit inside a functional group that owns specific behavior.

Key	Value
Kind	Engineering Model Term
Name	functional unit
Mentioned In	State Lifecycle View

TERM-GENERATION-WORKFLOW

Orchestrated run that combines model loading, validation, projection, rendering, and artifact emission.

Key	Value
Kind	Engineering Model Term

Key	Value
Name	generation workflow
Mentioned In	n/a

TERM-INFERENCE-HINT

Authored source and ownership configuration used to discover runtime, code, and verification evidence.

Key	Value
Kind	Engineering Model Term
Name	inference hint
Mentioned In	n/a

TERM-INFERRED-MAPPING

A discovered relationship that links inferred runtime/code elements upward to authored design.

Key	Value
Kind	Engineering Model Term
Name	inferred mapping
Mentioned In	n/a

TERM-INTERFACE

An authored interface boundary (for example API, channel, endpoint, or contract) owned by a functional unit.

Key	Value
Kind	Engineering Model Term
Name	interface
Mentioned In	Communication View , Deployment View

TERM-LINT-RUN

Requirement lint configuration that controls parsing and quality checks for requirement text.

Key	Value
Kind	Engineering Model Term
Name	lint run

Key	Value
Mentioned In	n/a

TERM-LOBSTER-ACTIVITY-TRACE

Generated LOBSTER activity JSON that links verification evidence back to formal requirement identifiers.

Key	Value
Kind	Engineering Model Term
Name	LOBSTER activity trace
Mentioned In	n/a

TERM-MCP-SERVER

Model Context Protocol server that exposes engineering-model operations to AI agents through JSON-RPC tools.

Key	Value
Kind	Engineering Model Term
Name	MCP server
Mentioned In	n/a

TERM-MCP-STDIO-TRANSPORT

Content-Length framed standard input/output transport used by the MCP command-line server.

Key	Value
Kind	Engineering Model Term
Name	MCP stdio transport
Mentioned In	n/a

TERM-MCP-TOOL

Named MCP operation with a constrained input schema and structured response payload.

Key	Value
Kind	Engineering Model Term
Name	MCP tool
Mentioned In	n/a

TERM-MCP-TOOL-RESPONSE

Structured MCP tool payload that includes success state, schema version, generated timestamp, and result data or validation error.

Key	Value
Kind	Engineering Model Term
Name	MCP tool response
Mentioned In	n/a

TERM-MODEL

The authored architecture model root that composes functional structure, relationships, inference hints, and views.

Key	Value
Kind	Engineering Model Term
Name	model
Mentioned In	Security View

TERM-OPEN-OTM-DOCUMENT

Open Threat Model JSON representation generated from the engineering model for interoperable threat-model exchange.

Key	Value
Kind	Engineering Model Term
Name	Open OTM document
Mentioned In	n/a

TERM-OSCAL-ASSESSMENT-RESULTS

Generated OSCAL assessment results that summarize reviewed controls, verification findings, and modeled risks.

Key	Value
Kind	Engineering Model Term
Name	OSCAL assessment results
Mentioned In	n/a

TERM-OSCAL-POAM

Generated OSCAL plan of action and milestones that maps modeled POA&M items and related risks into compliance JSON.

Key	Value
Kind	Engineering Model Term
Name	OSCAL POA&M
Mentioned In	n/a

TERM-OSCAL-SSP

Generated OSCAL system security plan that maps authored system metadata, components, controls, allocations, and evidence into SSP JSON.

Key	Value
Kind	Engineering Model Term
Name	OSCAL SSP
Mentioned In	n/a

TERM-POAM-ITEM

Plan of action and milestones item linked to a modeled risk and supporting artifacts.

Key	Value
Kind	Engineering Model Term
Name	POA&M item
Mentioned In	n/a

TERM-REFERENCE-INDEX

Generated index of authored, catalog, runtime, code, and verification references with stable anchors and backlinks.

Key	Value
Kind	Engineering Model Term
Name	reference index
Mentioned In	n/a

TERM-REFERENCED-ELEMENT

An architecture-relevant external, platform, or third-party dependency represented by role.

Key	Value
Kind	Engineering Model Term
Name	referenced element
Mentioned In	n/a

TERM-REPO-INDEX

Bounded first-party source index used to answer model-aware file, requirement, control, and threat lookup queries.

Key	Value
Kind	Engineering Model Term
Name	repository index
Mentioned In	n/a

TERM-REQUIREMENT

A structured requirement statement that defines expected system behavior and maps to functional ownership.

Key	Value
Kind	Engineering Model Term
Name	requirement
Mentioned In	Architecture Intent View , Deployment View , Traceability View , Interaction Flow View , REQ-PAY-008 , REQ-PAY-009

TERM-RISK

Authored risk record with likelihood, impact, response, scope, controls, and evidence.

Key	Value
Kind	Engineering Model Term
Name	risk
Mentioned In	Architecture Intent View , Deployment View , Security View

TERM-RUNTIME-ELEMENT

An inferred runtime realization element discovered from infrastructure and deployment sources.

Key	Value
Kind	Engineering Model Term
Name	runtime element
Mentioned In	n/a

TERM-SECURITY-CONTEXT

Security-focused generated context view that groups owned functional units and shows external actors, references, flows, controls, and trust boundaries.

Key	Value
Kind	Engineering Model Term
Name	security context
Mentioned In	n/a

TERM-SOURCE-BLOCK

Stable source reference block that records file path, optional line span, kind, summary, and linked entity IDs.

Key	Value
Kind	Engineering Model Term
Name	source block
Mentioned In	n/a

TERM-STATE

An authored lifecycle state used to model transition behavior, guards, and event-driven progression.

Key	Value
Kind	Engineering Model Term
Name	state
Mentioned In	Architecture Intent View , Deployment View , State Lifecycle View

TERM-STRUCTURIZR-DSL

Generated Structurizr DSL workspace that projects authored architecture, relationships, dynamic views, and deployment metadata.

Key	Value
Kind	Engineering Model Term
Name	Structurizr DSL
Mentioned In	n/a

TERM-THREAT-ASSUMPTION

Authored security assumption that records scope, rationale, owner, status, and evidence.

Key	Value
Kind	Engineering Model Term
Name	threat assumption
Mentioned In	n/a

TERM-THREAT-DRAGON-DOCUMENT

Threat Dragon JSON representation generated from the engineering model for STRIDE threat-model review.

Key	Value
Kind	Engineering Model Term
Name	Threat Dragon document
Mentioned In	n/a

TERM-THREAT-MITIGATION

Authored mitigation record that links a threat scenario to a control, effectiveness, verification, and evidence.

Key	Value
Kind	Engineering Model Term
Name	threat mitigation
Mentioned In	n/a

TERM-THREAT-MODEL-EXPORT

Generated security artifact that translates authored architecture, flows, trust boundaries, threats, and mitigations into an external threat-model schema.

Key	Value
Kind	Engineering Model Term
Name	threat model export
Mentioned In	n/a

TERM-THREAT-OUT-OF-SCOPE

Authorized decision that excludes a threat concern from current scope with reason, owner, expiry, and evidence.

Key	Value
Kind	Engineering Model Term
Name	threat out-of-scope decision
Mentioned In	n/a

TERM-THREAT-SCENARIO

Authorized threat narrative that connects attack vectors, scope, flows, controls, risks, and verification evidence.

Key	Value
Kind	Engineering Model Term
Name	threat scenario
Mentioned In	n/a

TERM-TRACE-MARKER

Source-level marker such as TRLC-LINKS or ENGMODEL-LINKS used to connect declarations to requirements and model entities.

Key	Value
Kind	Engineering Model Term
Name	trace marker
Mentioned In	n/a

TERM-TRLC-PACKAGE

Generated TRLC model and requirements package used for formal requirement traceability processing.

Key	Value
Kind	Engineering Model Term
Name	TRLC package
Mentioned In	n/a

TERM-TRUST-BOUNDARY

An authored trust separation zone that marks policy, identity, or security control boundaries.

Key	Value
Kind	Engineering Model Term
Name	trust boundary
Mentioned In	Security View

TERM-UPWARD-LINKING

Rule where runtime and code elements point to stable functional groups/units; authored architecture does not depend on inferred IDs.

Key	Value
Kind	Engineering Model Term
Name	upward linking
Mentioned In	n/a

TERM-VALIDATION

Model quality gate that checks authored documents, references, relationship semantics, and requirement lint results.

Key	Value
Kind	Engineering Model Term
Name	validation
Mentioned In	Security View

TERM-VALIDATION-DIAGNOSTIC

Structured validation finding with code, severity, message, and optional source path.

Key	Value
Kind	Engineering Model Term
Name	validation diagnostic
Mentioned In	n/a

TERM-VERIFICATION-CHECK

An inferred or authored verification artifact that validates requirement behavior with test evidence.

Key	Value
Kind	Engineering Model Term
Name	verification check
Mentioned In	n/a

TERM-VIEW

Authored projection configuration that selects roots, entity kinds, mappings, audience, and abstraction.

Key	Value
Kind	Engineering Model Term
Name	view
Mentioned In	Communication View , Deployment View , Security View , Traceability View , State Lifecycle View , Interaction Flow View

14.3. Inferred Runtime References

payments

provisions the shared EKS control plane that hosts payments and risk workloads

Key	Value
Kind	Runtime cluster
Owner	FU-CLUSTER-PROVISIONING
Source	examples/payments-engineering-sample/infra/terraform/main.tf
Mentioned In	n/a

flux-system/payments-sample-source

tracks the desired repository state that drives Flux reconciliation for payments workloads

Key	Value
Kind	Runtime gitrepository
Owner	FU-GITOPS-OPERATIONS
Source	examples/payments-engineering-sample/infra/flux/sources/payments-source.yaml
Mentioned In	Deployment View

payments/checkout-api

exposes checkout ingress and forwards normalized payment requests to authorization flow

Key	Value
Kind	Runtime helmrelease
Owner	FU-CHECKOUT
Source	examples/payments-engineering-sample/infra/flux/releases/checkout-api.yaml
Mentioned In	Deployment View , Security View

payments/payment-engine

executes payment authorization decisions and coordinates fraud checks plus bank callbacks

Key	Value
Kind	Runtime helmrelease
Owner	FU-PAYMENT-AUTHORIZATION
Source	examples/payments-engineering-sample/infra/flux/releases/payment-engine.yaml
Mentioned In	Deployment View , Security View

risk/risk-scorer

computes fraud risk score signals and persists evidence used by authorization decisions

Key	Value
Kind	Runtime helmrelease
Owner	FU-RISK-SCORING
Source	examples/payments-engineering-sample/infra/flux/releases/risk-scorer.yaml

Key	Value
Mentioned In	Deployment View , Security View

flux-system/payments-apps

applies and reconciles HelmRelease definitions for checkout, payment, and risk services

Key	Value
Kind	Runtime kustomization
Owner	FU-GITOPS-OPERATIONS
Source	examples/payments-engineering-sample/infra/flux/kustomizations/payments-apps.yaml
Mentioned In	Deployment View

flux_system

control-plane namespace where Flux GitOps operators reconcile deployment state

Key	Value
Kind	Runtime namespace
Owner	FU-GITOPS-OPERATIONS
Source	examples/payments-engineering-sample/infra/terraform/main.tf
Mentioned In	Deployment View

payments

runtime namespace boundary for checkout and payment authorization workloads

Key	Value
Kind	Runtime namespace
Owner	FU-CHECKOUT
Source	examples/payments-engineering-sample/infra/terraform/main.tf
Mentioned In	n/a

risk

runtime namespace boundary for fraud scoring and review support workloads

Key	Value
Kind	Runtime namespace
Owner	FU-RISK-SCORING
Source	examples/payments-engineering-sample/infra/terraform/main.tf
Mentioned In	n/a

14.4. Inferred Code References

[gopkg.in/yaml.v3 \(checkout_api.go\)](#)

Inferred library_external dependency owned by FU-CHECKOUT from checkout_api.go.

Key	Value
Kind	Code library_external
Owner	FU-CHECKOUT
Source	checkout_api.go
Mentioned In	n/a

[serde_json::json \(payment_engine.rs\)](#)

Inferred library_external dependency owned by FU-PAYMENT-AUTHORIZATION from payment_engine.rs.

Key	Value
Kind	Code library_external
Owner	FU-PAYMENT-AUTHORIZATION
Source	payment_engine.rs
Mentioned In	n/a

[zod \(risk_scorer.ts\)](#)

Inferred library_external dependency owned by FU-RISK-SCORING from risk_scorer.ts.

Key	Value
Kind	Code library_external
Owner	FU-RISK-SCORING
Source	risk_scorer.ts

Key	Value
Mentioned In	n/a

[./support/audit_envelope \(risk_scorer.ts\)](#)

Inferred library_first_party dependency owned by FU-RISK-SCORING from risk_scorer.ts.

Key	Value
Kind	Code library_first_party
Owner	FU-RISK-SCORING
Source	risk_scorer.ts
Mentioned In	n/a

[crate::domain::events::PaymentEvent \(payment_engine.rs\)](#)

Inferred library_first_party dependency owned by FU-PAYMENT-AUTHORIZATION from payment_engine.rs.

Key	Value
Kind	Code library_first_party
Owner	FU-PAYMENT-AUTHORIZATION
Source	payment_engine.rs
Mentioned In	n/a

[github.com/labeth/engineering-model-go/validate \(checkout_api.go\)](#)

Inferred library_first_party dependency owned by FU-CHECKOUT from checkout_api.go.

Key	Value
Kind	Code library_first_party
Owner	FU-CHECKOUT
Source	checkout_api.go
Mentioned In	n/a

[fmt \(checkout_api.go\)](#)

Inferred library_stdlib dependency owned by FU-CHECKOUT from checkout_api.go.

Key	Value
Kind	Code library_stdlib
Owner	FU-CHECKOUT
Source	checkout_api.go
Mentioned In	n/a

audit_envelope.ts

formats support-review audit envelopes for traceability workflows

Key	Value
Kind	Code source_file
Owner	FU-RISK-SCORING
Source	support/audit_envelope.ts
Mentioned In	n/a

checkout_api.go

accepts checkout requests and forwards payment authorization flow input

Key	Value
Kind	Code source_file
Owner	FU-CHECKOUT
Source	checkout_api.go
Mentioned In	Deployment View , Security View

events.rs

defines payment domain events used across authorization and risk paths

Key	Value
Kind	Code source_file
Owner	FU-PAYMENT-AUTHORIZATION
Source	domain/events.rs
Mentioned In	n/a

payment_engine.rs

executes authorization decisions and persists payment-side audit records

Key	Value
Kind	Code source_file
Owner	FU-PAYMENT-AUTHORIZATION
Source	payment_engine.rs
Mentioned In	Deployment View , Security View

risk_scorer.ts

computes fraud risk scores and decides review or decline outcomes

Key	Value
Kind	Code source_file
Owner	FU-RISK-SCORING
Source	risk_scorer.ts
Mentioned In	Deployment View , Security View

audit_envelope.ts:11

Inferred code symbol owned by FU-RISK-SCORING from support/audit_envelope.ts:11.

Key	Value
Kind	Code symbol
Owner	FU-RISK-SCORING
Source	support/audit_envelope.ts:11
Mentioned In	n/a

checkout_api.go:13

Inferred code symbol owned by FU-CHECKOUT from checkout_api.go:13.

Key	Value
Kind	Code symbol
Owner	FU-CHECKOUT

Key	Value
Source	checkout_api.go:13
Mentioned In	n/a

checkout_api.go:16

Inferred code symbol owned by FU-CHECKOUT from checkout_api.go:16.

Key	Value
Kind	Code symbol
Owner	FU-CHECKOUT
Source	checkout_api.go:16
Mentioned In	n/a

checkout_api.go:20

Inferred code symbol owned by FU-CHECKOUT from checkout_api.go:20.

Key	Value
Kind	Code symbol
Owner	FU-CHECKOUT
Source	checkout_api.go:20
Mentioned In	n/a

checkout_api.go:32

Inferred code symbol owned by FU-CHECKOUT from checkout_api.go:32.

Key	Value
Kind	Code symbol
Owner	FU-CHECKOUT
Source	checkout_api.go:32
Mentioned In	n/a

checkout_api.go:38

Inferred code symbol owned by FU-CHECKOUT from checkout_api.go:38.

Key	Value
Kind	Code symbol
Owner	FU-CHECKOUT
Source	checkout_api.go:38
Mentioned In	n/a

checkout_api.go:44

Inferred code symbol owned by FU-CHECKOUT from checkout_api.go:44.

Key	Value
Kind	Code symbol
Owner	FU-CHECKOUT
Source	checkout_api.go:44
Mentioned In	n/a

checkout_api.go:50

Inferred code symbol owned by FU-CHECKOUT from checkout_api.go:50.

Key	Value
Kind	Code symbol
Owner	FU-CHECKOUT
Source	checkout_api.go:50
Mentioned In	n/a

checkout_api.go:56

Inferred code symbol owned by FU-CHECKOUT from checkout_api.go:56.

Key	Value
Kind	Code symbol
Owner	FU-CHECKOUT
Source	checkout_api.go:56
Mentioned In	n/a

events.rs:12

Inferred code symbol owned by FU-PAYMENT-AUTHORIZATION from domain/events.rs:12.

Key	Value
Kind	Code symbol
Owner	FU-PAYMENT-AUTHORIZATION
Source	domain/events.rs:12
Mentioned In	n/a

events.rs:4

Inferred code symbol owned by FU-PAYMENT-AUTHORIZATION from domain/events.rs:4.

Key	Value
Kind	Code symbol
Owner	FU-PAYMENT-AUTHORIZATION
Source	domain/events.rs:4
Mentioned In	n/a

payment_engine.rs:10

Inferred code symbol owned by FU-PAYMENT-AUTHORIZATION from payment_engine.rs:10.

Key	Value
Kind	Code symbol
Owner	FU-PAYMENT-AUTHORIZATION
Source	payment_engine.rs:10
Mentioned In	n/a

payment_engine.rs:15

Inferred code symbol owned by FU-PAYMENT-AUTHORIZATION from payment_engine.rs:15.

Key	Value
Kind	Code symbol
Owner	FU-PAYMENT-AUTHORIZATION

Key	Value
Source	payment_engine.rs:15
Mentioned In	n/a

payment_engine.rs:31

Inferred code symbol owned by FU-PAYMENT-AUTHORIZATION from payment_engine.rs:31.

Key	Value
Kind	Code symbol
Owner	FU-PAYMENT-AUTHORIZATION
Source	payment_engine.rs:31
Mentioned In	n/a

payment_engine.rs:40

Inferred code symbol owned by FU-PAYMENT-AUTHORIZATION from payment_engine.rs:40.

Key	Value
Kind	Code symbol
Owner	FU-PAYMENT-AUTHORIZATION
Source	payment_engine.rs:40
Mentioned In	n/a

payment_engine.rs:51

Inferred code symbol owned by FU-PAYMENT-AUTHORIZATION from payment_engine.rs:51.

Key	Value
Kind	Code symbol
Owner	FU-PAYMENT-AUTHORIZATION
Source	payment_engine.rs:51
Mentioned In	n/a

payment_engine.rs:60

Inferred code symbol owned by FU-PAYMENT-AUTHORIZATION from payment_engine.rs:60.

Key	Value
Kind	Code symbol
Owner	FU-PAYMENT-AUTHORIZATION
Source	payment_engine.rs:60
Mentioned In	n/a

payment_engine.rs:69

Inferred code symbol owned by FU-PAYMENT-AUTHORIZATION from payment_engine.rs:69.

Key	Value
Kind	Code symbol
Owner	FU-PAYMENT-AUTHORIZATION
Source	payment_engine.rs:69
Mentioned In	n/a

payment_engine.rs:7

Inferred code symbol owned by FU-PAYMENT-AUTHORIZATION from payment_engine.rs:7.

Key	Value
Kind	Code symbol
Owner	FU-PAYMENT-AUTHORIZATION
Source	payment_engine.rs:7
Mentioned In	n/a

risk_scorer.ts:10

Inferred code symbol owned by FU-RISK-SCORING from risk_scorer.ts:10.

Key	Value
Kind	Code symbol
Owner	FU-RISK-SCORING
Source	risk_scorer.ts:10
Mentioned In	n/a

risk_scorer.ts:24

Inferred code symbol owned by FU-RISK-SCORING from risk_scorer.ts:24.

Key	Value
Kind	Code symbol
Owner	FU-RISK-SCORING
Source	risk_scorer.ts:24
Mentioned In	n/a

risk_scorer.ts:33

Inferred code symbol owned by FU-RISK-SCORING from risk_scorer.ts:33.

Key	Value
Kind	Code symbol
Owner	FU-RISK-SCORING
Source	risk_scorer.ts:33
Mentioned In	n/a

risk_scorer.ts:40

Inferred code symbol owned by FU-RISK-SCORING from risk_scorer.ts:40.

Key	Value
Kind	Code symbol
Owner	FU-RISK-SCORING
Source	risk_scorer.ts:40
Mentioned In	n/a

risk_scorer.ts:43

Inferred code symbol owned by FU-RISK-SCORING from risk_scorer.ts:43.

Key	Value
Kind	Code symbol
Owner	FU-RISK-SCORING

Key	Value
Source	risk_scorer.ts:43
Mentioned In	n/a

risk_scorer.ts:52

Inferred code symbol owned by FU-RISK-SCORING from risk_scorer.ts:52.

Key	Value
Kind	Code symbol
Owner	FU-RISK-SCORING
Source	risk_scorer.ts:52
Mentioned In	n/a

risk_scorer.ts:58

Inferred code symbol owned by FU-RISK-SCORING from risk_scorer.ts:58.

Key	Value
Kind	Code symbol
Owner	FU-RISK-SCORING
Source	risk_scorer.ts:58
Mentioned In	n/a

risk_scorer.ts:7

Inferred code symbol owned by FU-RISK-SCORING from risk_scorer.ts:7.

Key	Value
Kind	Code symbol
Owner	FU-RISK-SCORING
Source	risk_scorer.ts:7
Mentioned In	n/a

14.5. Verification References

VER-INF-E2E-AUTHORIZED_CHECKOUT_FLOW-8C6597

executes authorized checkout flow from session start through payment authorization success

Key	Value
Kind	e2e
Status	not-run
Source	tests/e2e/authorized_checkout_flow.yaml
Name	Authorized Checkout Flow
Mentioned In	Interaction Flow View , Authorized Checkout Flow

VER-INF-INTEGRATION-AUDIT_RECORD_PERSISTENCE_TEST-B333A2

checks audit record persistence includes payment id and computed risk score

Key	Value
Kind	integration
Status	not-run
Source	tests/integration/audit_record_persistence_test.ts
Name	Audit Record Persistence Test
Mentioned In	Interaction Flow View , Audit Record Persistence Test

VER-INF-INTEGRATION-FRAUD_GATE_TEST-12F3BD

validates fraud gate escalation and block decisions before authorization completion

Key	Value
Kind	integration
Status	pass
Source	test-results/integration-fraud-gate.json (+1)
Name	Fraud Gate Test
Mentioned In	Interaction Flow View , Fraud Gate Test

VER-INF-TEST-CHECKOUT_DECLINE_RESPONSE_TEST-365ACE

validates checkout decline response contract includes reason and retry guidance

Key	Value
Kind	test
Status	pass
Source	test-results/contract-checkout-decline.json (+1)
Name	Checkout Decline Response Test
Mentioned In	Interaction Flow View , Checkout Decline Response Test

VER-INF-UNIT-CHECKOUT_DECLINE_REASON_TEST-5F4C93

validates checkout decline reason normalization and retry policy messaging

Key	Value
Kind	unit
Status	not-run
Source	tests/unit/checkout_decline_reason_test.go
Name	Checkout Decline Reason Test
Mentioned In	Interaction Flow View , Checkout Decline Reason Test

15. Gemara GRC Model

This chapter renders the model as OpenSSF Gemara (<https://gemara.openssf.org>) documents. Each artifact is built with the official `go-gemara` SDK types and validated against the published Gemara CUE schemas. Generate the full YAML set with `enggemara` ; query it via the `gemara.*` MCP tools.

Gemara Layer	Artifact	Entries
L1	Vector Catalog	4
L1	Principle Catalog	5
L1	Guidance Catalog	3
L2	Capability Catalog	7
L2	Control Catalog	3
L2	Threat Catalog	3
L3	Risk Catalog	4
L3	Policy	3
-	Control → Threat Mapping	2
-	Lexicon	33
L7	Audit Log	7
L6	Enforcement Log	1

15.1. Controls (L2)

Control	Objective	Group	Assessment Requirements
CTRL-PAYMENTS-SSO-MFA	Enforce MFA and conditional access for privileged operations.	identity-access	2
CTRL-PAYMENTS-IMAGE-DIGEST	Enforce immutable digest-pinned container image references.	supply-chain	1
CTRL-PAYMENTS-CALLBACK-NONCE	Enforce nonce freshness and idempotency on bank callback processing.	protocol-integrity	1

15.2. Threats (L2)

Threat	Title	Group
TS-PAYMENTS-CHECKOUT-SPOOFING	Checkout payload spoofing bypasses normalization checks	stride-tampering
TS-PAYMENTS-BANK-CALLBACK-REPLAY	Replayed bank callback triggers duplicate authorization transition	stride-replay
TS-PAYMENTS-RISK-TICKET-TAMPER	Manual review ticket tampering influences authorization result	stride-tampering

15.3. Risks (L3)

Risk	Title	Severity
RISK-PAYMENTS-SSO-MFA-GAP	Privileged SSO path bypass risk	High
RISK-PAYMENTS-CHECKOUT-SPOOFING	Checkout payload spoofing risk	High
RISK-PAYMENTS-BANK-CALLBACK-REPLAY	Bank callback replay risk	High
RISK-PAYMENTS-MANUAL-REVIEW-TAMPER	Manual review decision tampering risk	Medium